



Penetration Testing1



PART 4

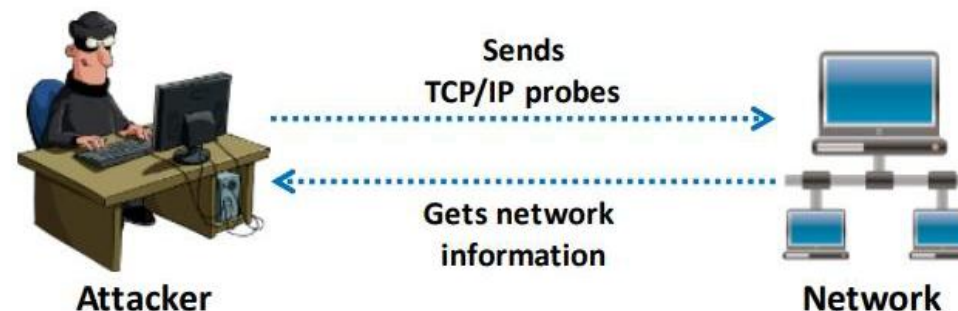
Scanning Networks.

Assistant Teacher: Mubarak Altamimi.

Overview of Network Scanning

- Network scanning refers to a set of procedures used for **identifying hosts, ports, and services** in a network
- Network scanning is one of the **components of intelligence gathering** which can be used by an attacker to create a profile of the target organization

Network Scanning Process

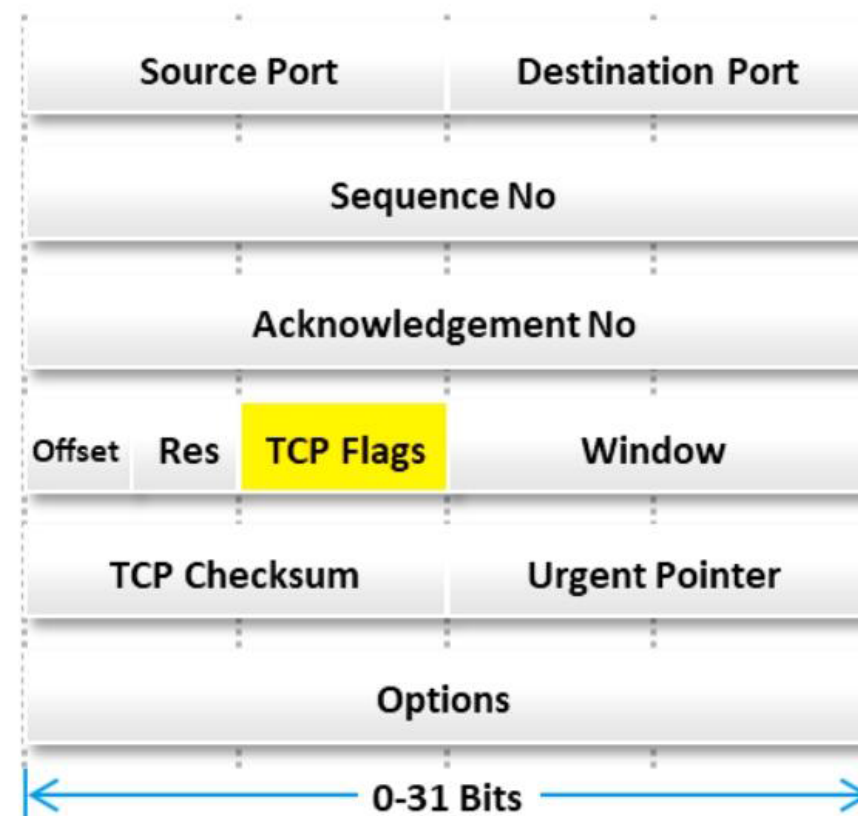
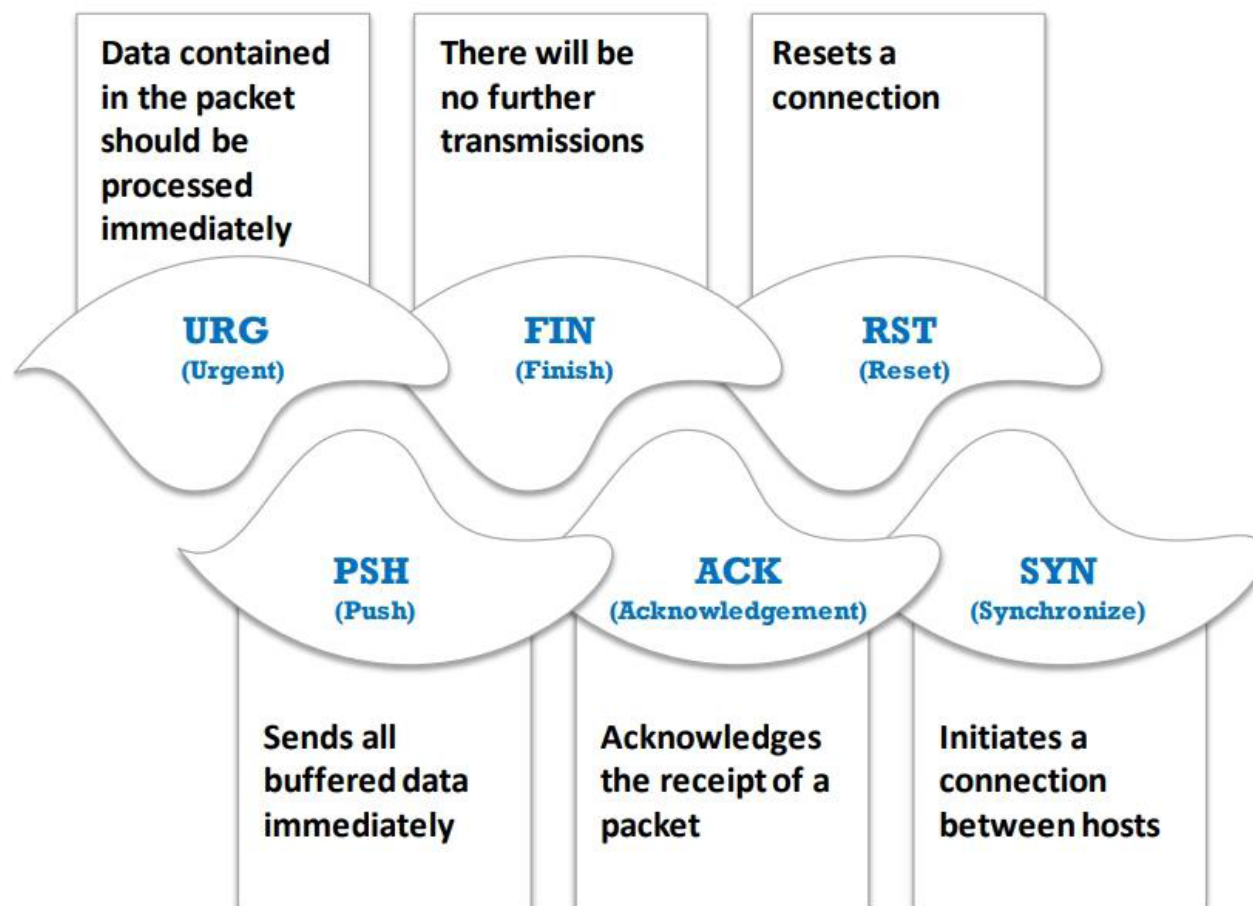


Objectives of Network Scanning

- To discover live hosts, IP address, and open ports of live hosts
- To discover operating systems and system architecture
- To discover services running on hosts
- To discover vulnerabilities in live hosts



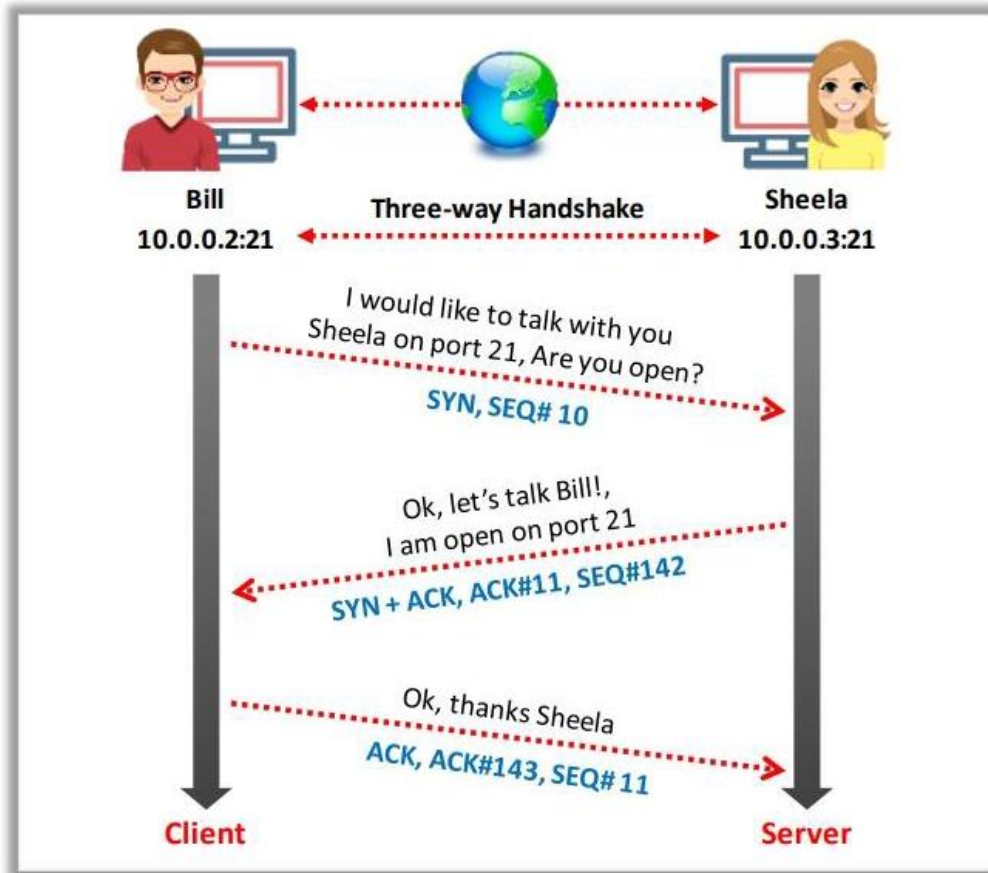
TCP Communication Flags



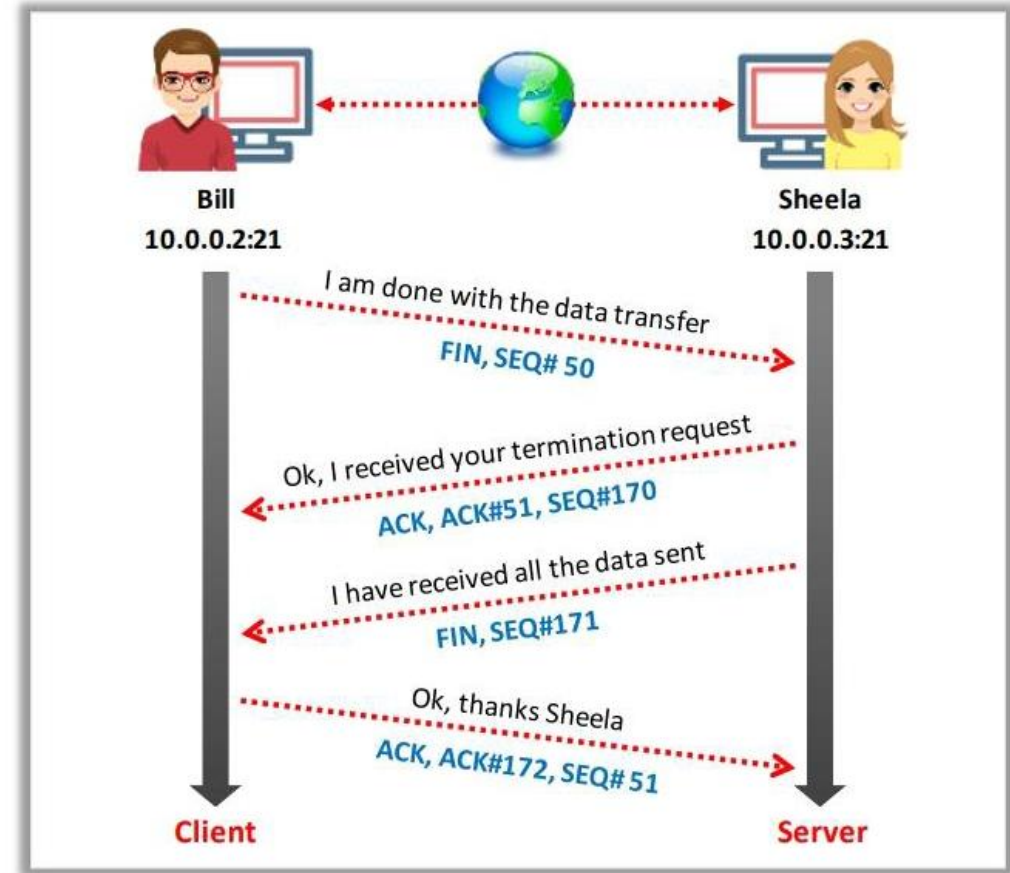
Standard TCP communications are controlled by flags in the TCP packet header

TCP/IP Communication

TCP Session Establishment (Three-way Handshake)

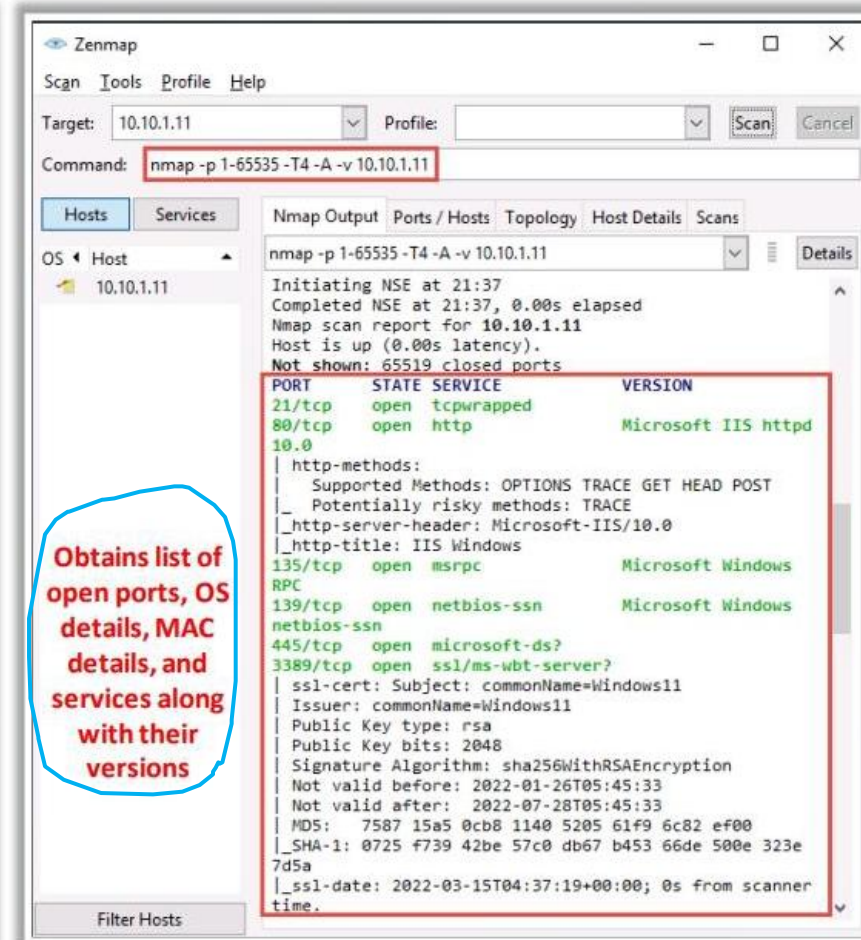
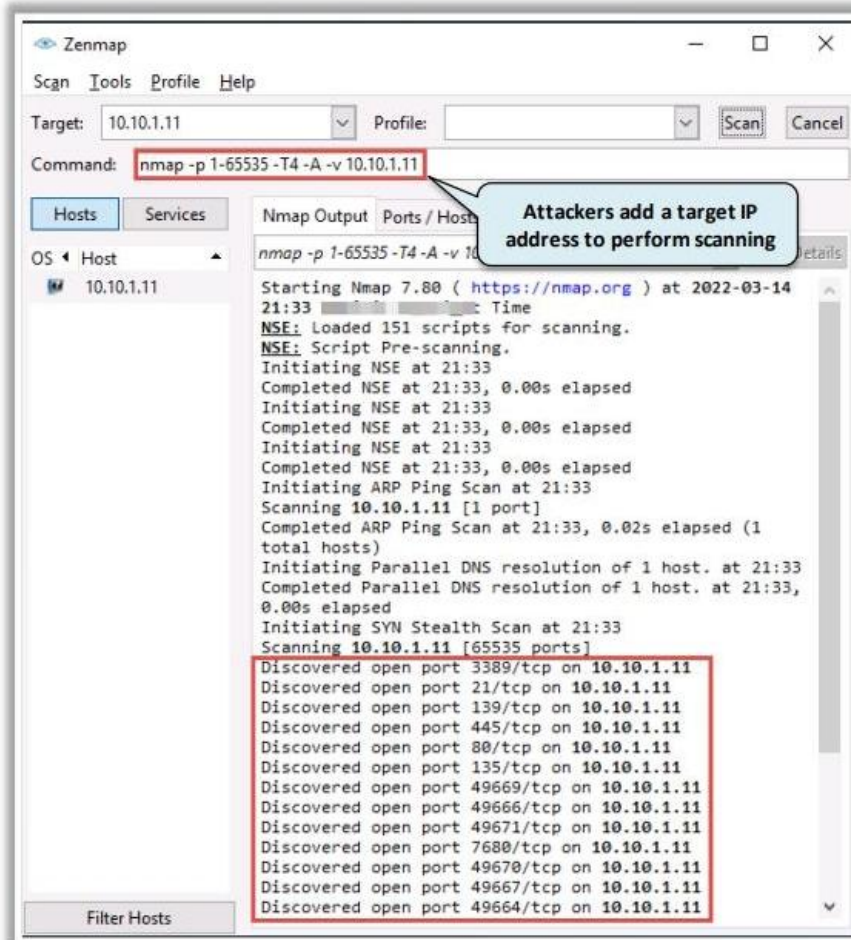


TCP Session Termination



Scanning Tools: Nmap

- Network administrators can use Nmap for **inventorying a network**, managing service upgrade schedules, and monitoring host or service uptime
- Attackers use Nmap to extract information such as **live hosts on the network**, **open ports**, **services** (application name and version), **types of packet filters/firewalls**, as well as **operating systems and versions used**



<https://nmap.org>

Scanning Tools: Hping3

- 1 Command line **network scanning** and **packet crafting** tool for the TCP/IP protocol
- 2 It can be used for **network security auditing**, **firewall testing**, manual path MTU discovery, advanced traceroute, remote OS fingerprinting, remote uptime guessing, TCP/IP stacks auditing, etc. **maximum transmission unit (MTU) size**

ICMP Scanning

```
hping3 -1 10.10.1.11 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#hping3 -1 10.10.1.11
HPING 10.10.1.11 (eth0 10.10.1.11): icmp mode set, 28 headers + 0 data bytes
len=28 ip=10.10.1.11 ttl=128 id=53015 icmp_seq=0 rtt=3.9 ms
len=28 ip=10.10.1.11 ttl=128 id=53016 icmp_seq=1 rtt=3.7 ms
len=28 ip=10.10.1.11 ttl=128 id=53017 icmp_seq=2 rtt=7.6 ms
len=28 ip=10.10.1.11 ttl=128 id=53018 icmp_seq=3 rtt=7.6 ms
len=28 ip=10.10.1.11 ttl=128 id=53019 icmp_seq=4 rtt=7.5 ms
len=28 ip=10.10.1.11 ttl=128 id=53020 icmp_seq=5 rtt=7.4 ms
len=28 ip=10.10.1.11 ttl=128 id=53021 icmp_seq=6 rtt=11.3 ms
len=28 ip=10.10.1.11 ttl=128 id=53022 icmp_seq=7 rtt=3.2 ms
len=28 ip=10.10.1.11 ttl=128 id=53023 icmp_seq=8 rtt=3.1 ms
len=28 ip=10.10.1.11 ttl=128 id=53024 icmp_seq=9 rtt=3.0 ms
^C
--- 10.10.1.11 hping statistic ---
10 packets transmitted, 10 packets received, 0% packet loss
round-trip min/avg/max = 3.0/5.8/11.3 ms
[root@parrot]~/home/attacker
#
```

ACK Scanning on port 80

```
hping3 -A 10.10.1.11 -p 80 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#hping3 -A 10.10.1.11 -p 80
HPING 10.10.1.11 (eth0 10.10.1.11): A set, 40 headers + 0 data bytes
len=40 ip=10.10.1.11 ttl=128 DF id=53036 sport=80 flags=R seq=0 win=0 rtt=7.9 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53037 sport=80 flags=R seq=1 win=0 rtt=3.8 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53038 sport=80 flags=R seq=2 win=0 rtt=3.7 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53039 sport=80 flags=R seq=3 win=0 rtt=10.5 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53040 sport=80 flags=R seq=4 win=0 rtt=10.4 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53041 sport=80 flags=R seq=5 win=0 rtt=2.3 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53042 sport=80 flags=R seq=6 win=0 rtt=10.2 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53043 sport=80 flags=R seq=7 win=0 rtt=14.1 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53044 sport=80 flags=R seq=8 win=0 rtt=10.0 ms
len=40 ip=10.10.1.11 ttl=128 DF id=53045 sport=80 flags=R seq=9 win=0 rtt=14.0 ms
^C
--- 10.10.1.11 hping statistic ---
10 packets transmitted, 10 packets received, 0% packet loss
round-trip min/avg/max = 2.3/8.7/14.1 ms
[root@parrot]~/home/attacker
#
```

<http://www.hping.org>

Hping Commands

Lab. With Hping
command(parrot)



ICMP Ping

```
hping3 -1 10.0.0.25
```



ACK scan on port 80

```
hping3 -A 10.0.0.25 -p 80
```



UDP scan on port 80

```
hping3 -2 10.0.0.25 -p 80
```



Collecting Initial Sequence Number

```
hping3 192.168.1.103 -Q -p 139
```



Firewalls and Timestamps

```
hping3 -S 72.14.207.99 -p 80 --tcp-timestamp
```



SYN scan on port 50-60

```
hping3 -8 50-60 -S 10.0.0.25 -V
```



FIN, PUSH and URG scan on port 80

```
hping3 -F -P -U 10.0.0.25 -p 80
```



Scan entire subnet for live host

```
hping3 -1 10.0.1.x --rand-dest -I eth0
```



Intercept all traffic containing HTTP signature

```
hping3 -9 HTTP -I eth0
```



SYN flooding a victim

```
hping3 -S 192.168.1.1 -a 192.168.1.254 -p 22 --flood
```



Figure 3.12: Screenshot of IP Scanner

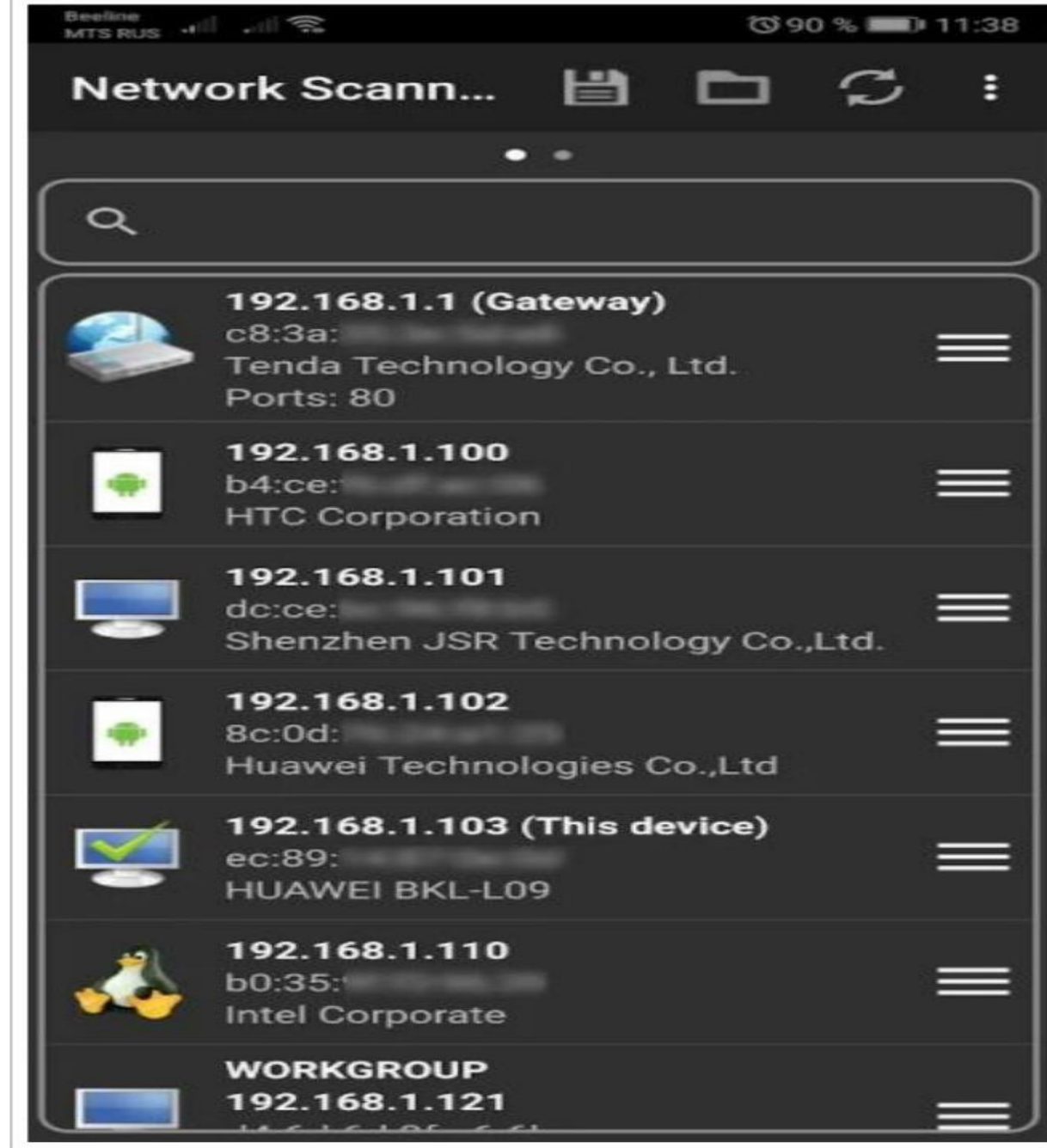
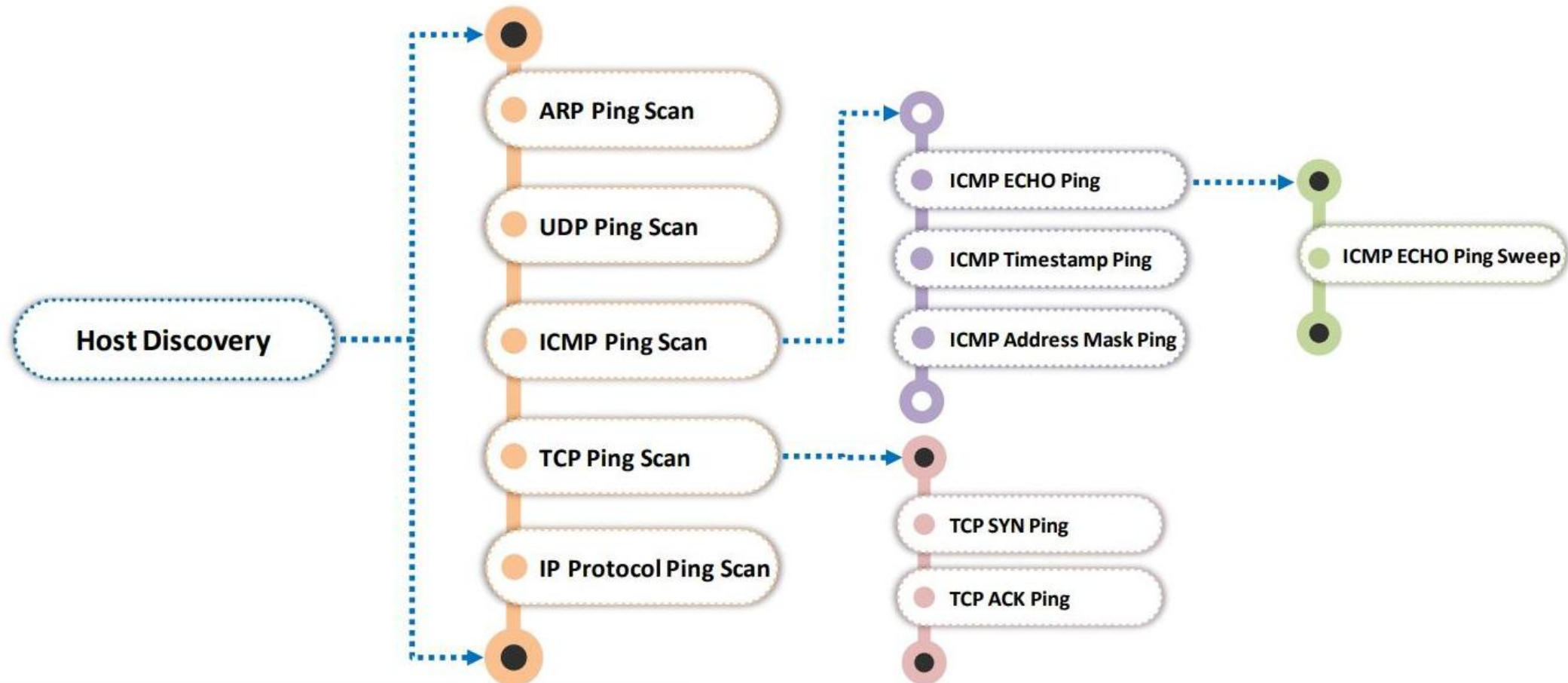


Figure 3.14: Screenshot of Network Scanner

Host Discovery Techniques

- Host discovery techniques are used to **identify the active/live systems** in the network



Host Discovery Techniques (Cont'd)

Response VS reply

**Lab. With
Nmap**



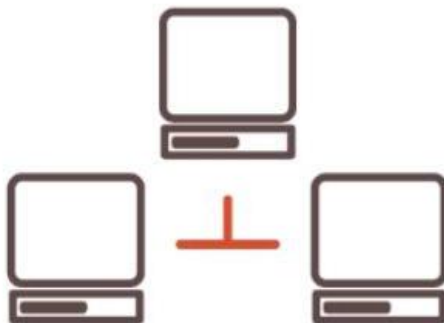
Scanning Technique	Nmap Command	Request	Response	Advantages
ARP Ping Scan	<code>nmap -sn -PR <Target IP Address></code>	ARP request probe	✓ ARP response - Host is active ✓ No response - Host is inactive	✓ More efficient and accurate than other host discovery techniques ✓ Useful for system discovery, where one may need to scan large address spaces
UDP Ping Scan	<code>nmap -sn -PU <Target IP Address></code>	UDP request	✓ UDP response - Host is active ✓ Error messages (host/network unreachable or TTL exceeded) - Host is inactive	✓ Detects systems behind firewalls with strict TCP filtering
ICMP ECHO Ping Scan	<code>nmap -sn -PE <Target IP Address></code>	ICMP ECHO request	✓ ICMP ECHO <u>reply</u> - Host is active ✓ No response - Host is inactive	✓ Useful for locating active devices or determining if the ICMP message passes through a firewall Disadvantage: ✓ Does not work on Windows-based networks

Host Discovery Techniques (Cont'd)

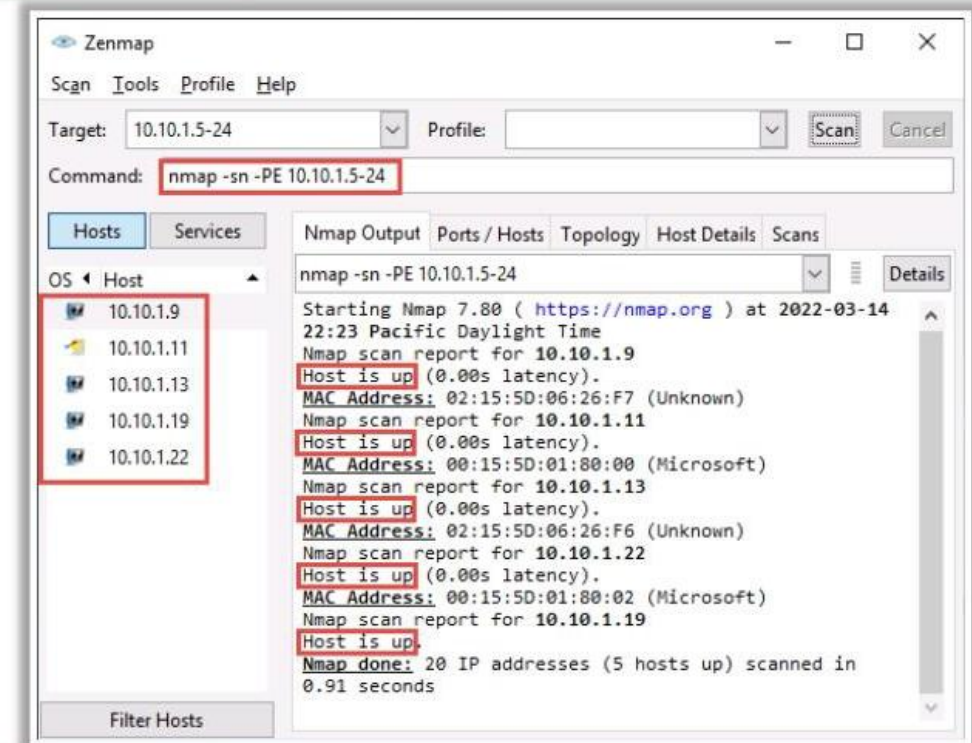
Scanning Technique	Nmap Command	Request	Response	Advantages
 ICMP ECHO Ping Sweep	<code>nmap -sn -PE <Target IP Address Range></code>	ICMP ECHO requests to multiple hosts	✓ ICMP ECHO reply - Host is active ✓ No response - Host is inactive	✓ Determines the live hosts from a range of IP addresses ✓ Useful for creating an inventory of live systems in the subnet Disadvantage: ✓ Oldest and slowest method used to scan a network
ICMP Timestamp Ping Scan	<code>nmap -sn -PP <Target IP Address></code>	ICMP timestamp request	✓ Timestamp reply to each timestamp request ✓ Response from the destination host is conditional, and it may or may not respond with the time value depending on its configuration by the administrator at the target's end	✓ Alternative for the conventional ICMP ECHO ping scan ✓ Determines whether the target host is live, specifically when the administrators block ICMP ECHO pings
ICMP Address Mask Ping Scan	<code>nmap -sn -PM <Target IP Address></code>	ICMP address mask request	✓ Address mask response from the destination host is conditional, and it may or may not respond with the appropriate subnet value depending on its configuration by the administrator at the target's end	✓ Alternative for the conventional ICMP ECHO ping scan ✓ Determines whether the target host is live, specifically when the administrators block ICMP ECHO pings
 TCP SYN Ping Scan	<code>nmap -sn -PS <Target IP Address></code>	Empty TCP SYN request	✓ ACK response - Host is active ✓ No response - Host is inactive	✓ Used to determine if the host is active without creating any connection ✓ Logs are not recorded at the system or network level, enabling the attacker to leave no traces for detection

Host Discovery Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages
TCP ACK Ping Scan	<code>nmap -sn -PA <Target IP Address></code>	Empty TCP ACK request	✓ RST response - Host is active ✓ No response - Host is inactive	✓ Maximizes the chances of bypassing the firewall
IP Protocol Ping Scan	<code>nmap -sn -PO <Target IP Address></code>	IP ping requests using different IP protocols (ICMP, IGMP, TCP, and UDP)	✓ Any response - Host is active ✓ No response - Host is inactive	✓ Sends different packets using different IP protocols in the hope of receiving a response indicating that a host is online



**ICMP ECHO
Ping Sweep**



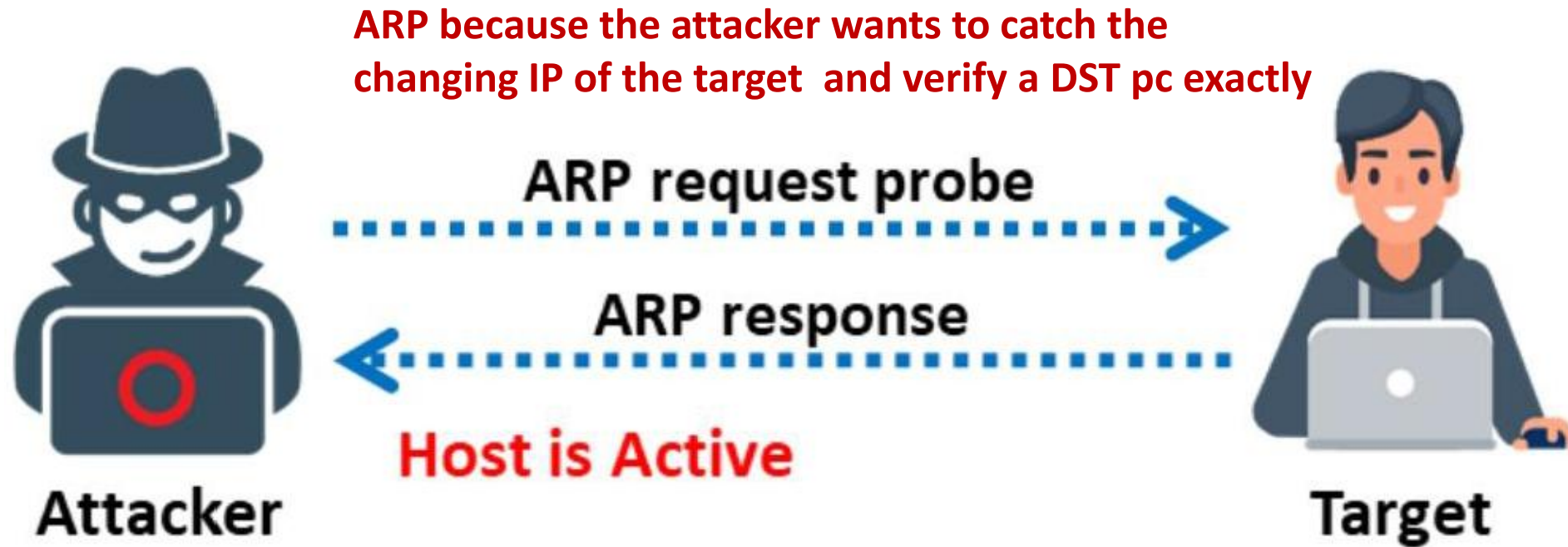


Figure 3.15: ARP ping scan

UDP because the security issue

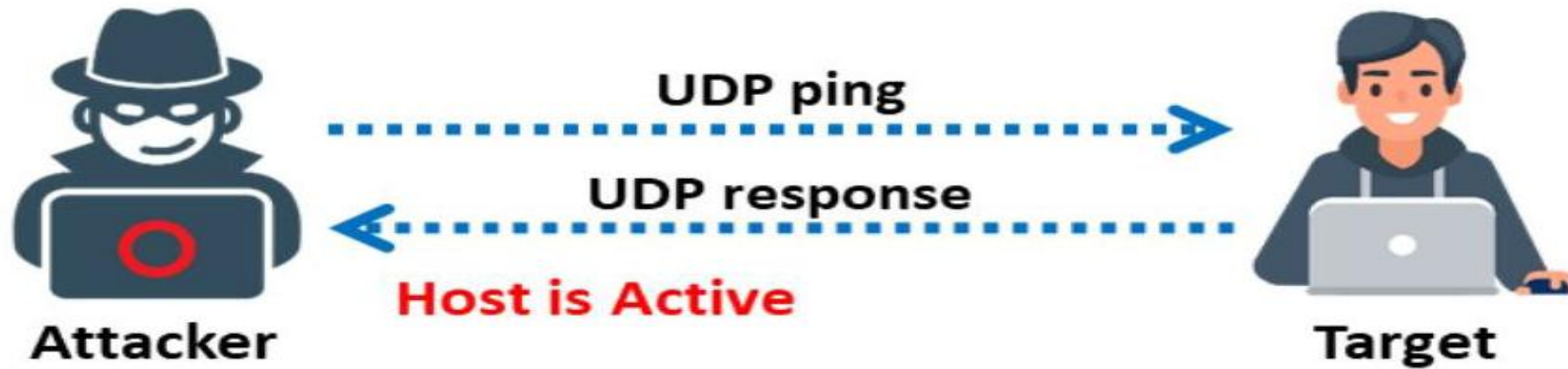
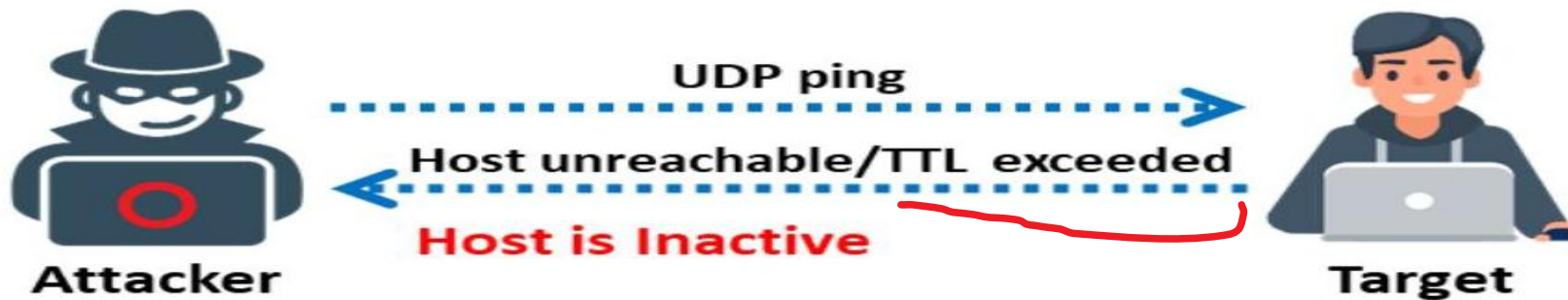


Figure 3.17: UDP ping scan to determine if the host is active



Attacker may couldn't
Get response with a
host, unreachable, TTL
exceeded(discarding
the packet by router.

Figure 3.18: UDP ping scan to determine if the host is offline

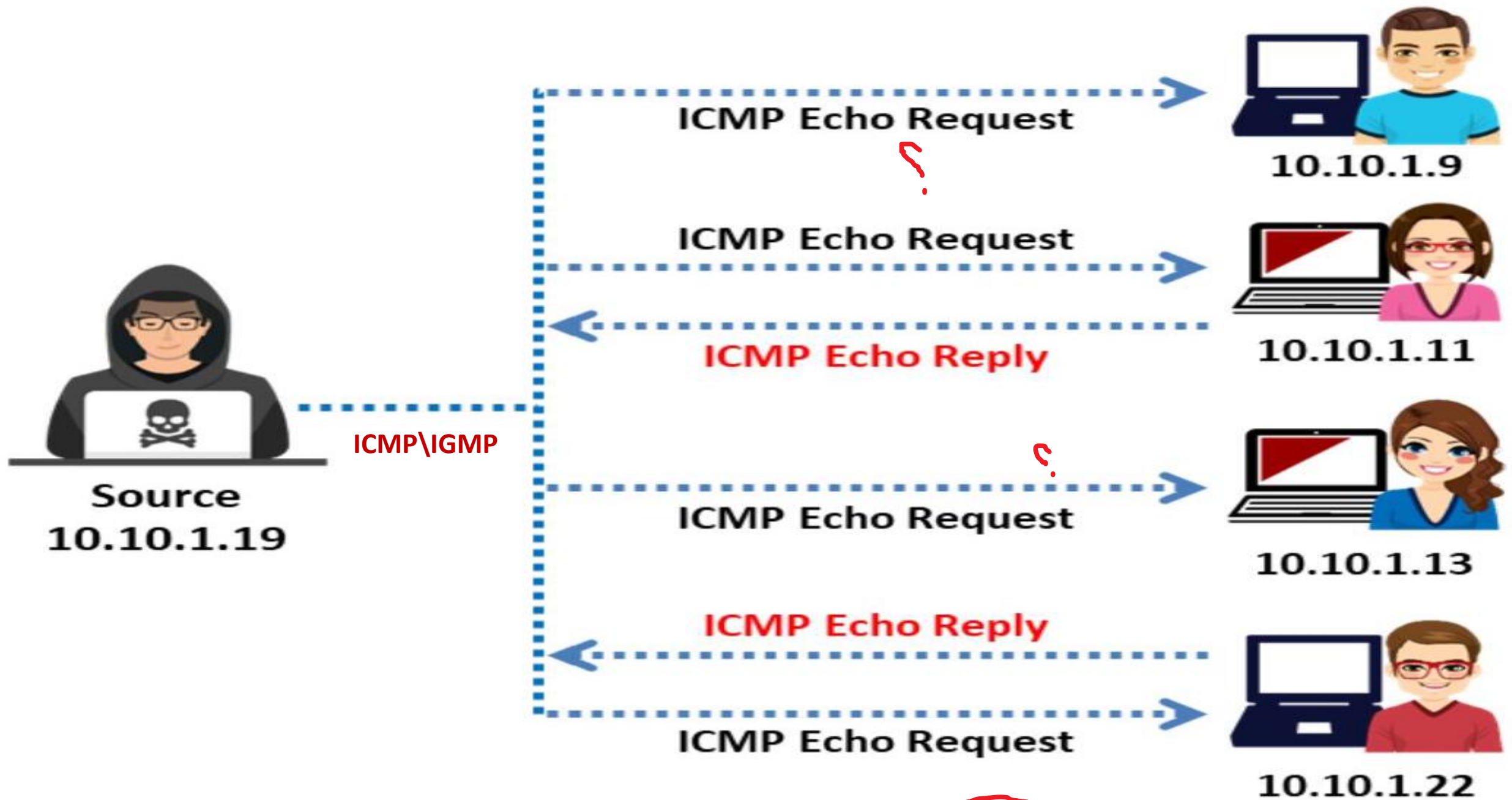


Figure 3.22: ICMP ECHO Ping Sweep

Attacker deal with a host to connect and get the ack, but maybe get RST that means the port TCP is close, or maybe the data can't process in destination.

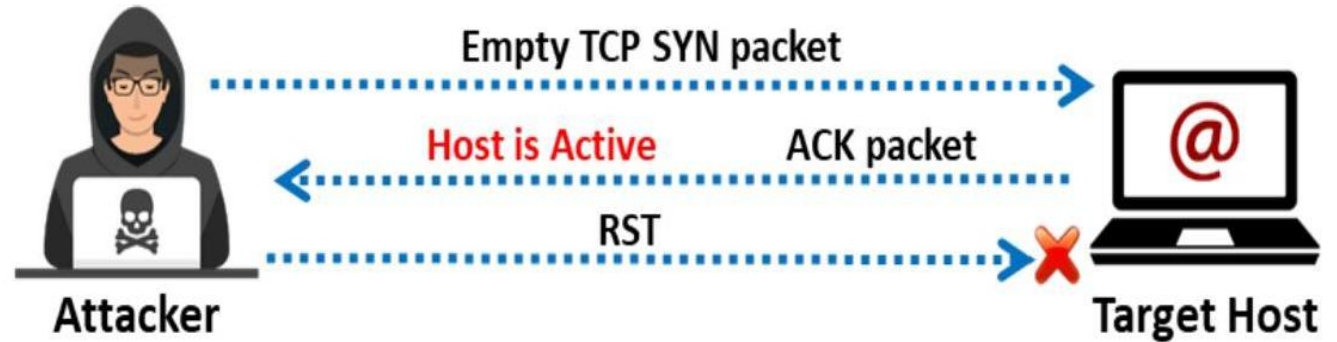


Figure 3.26: TCP SYN ping scan for host discovery

Attacker deal with a host to connect but get RST that means the port is close.

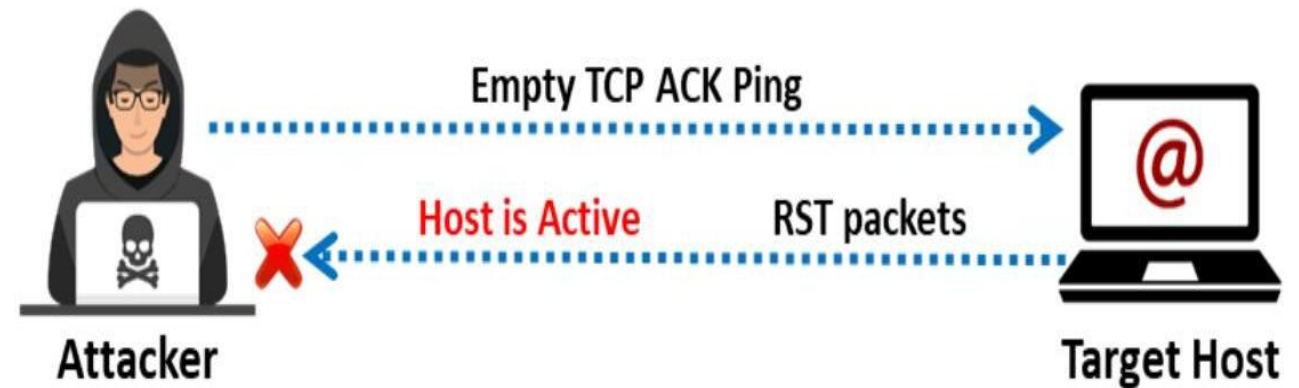


Figure 3.28: TCP ACK ping scan for host discovery

- Sometimes the host doesn't respond; it knows that the request is an attack(firewall, any security countermeasure).
- Or maybe it leaves the host connection hanging as pending(flood of ACK).

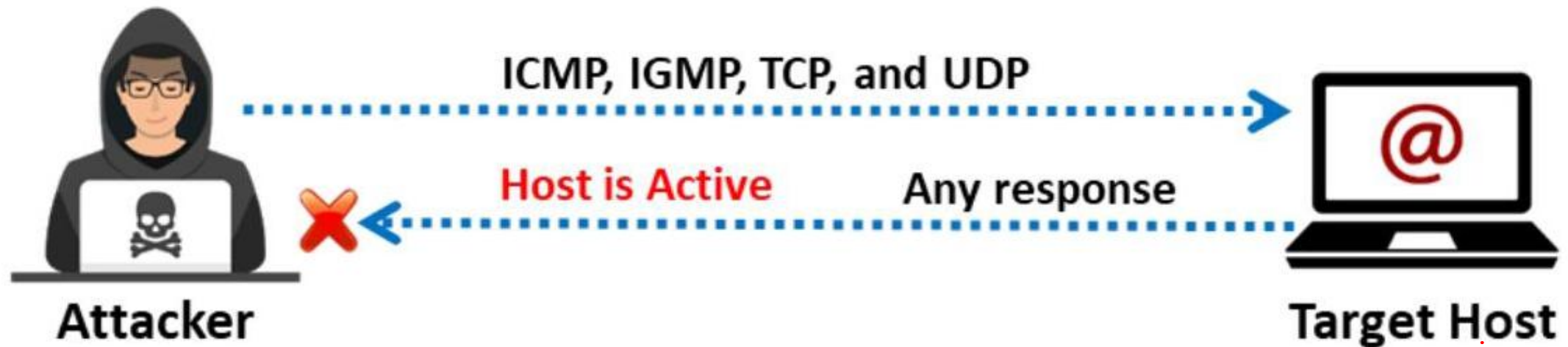
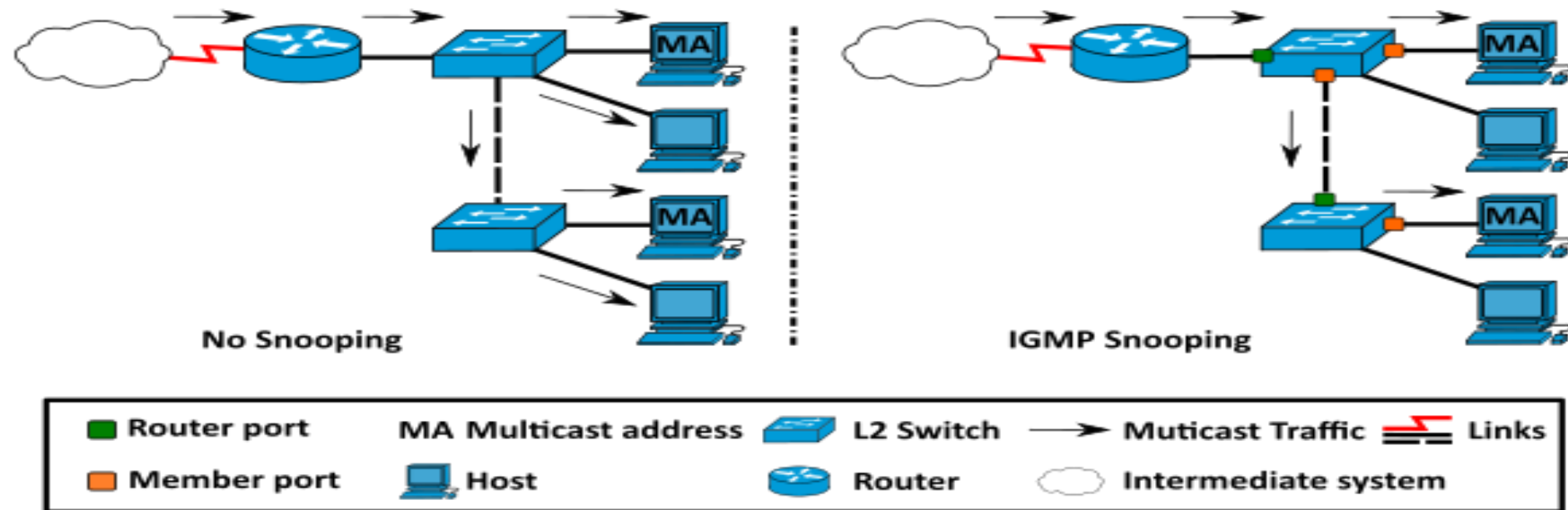


Figure 3.30: IP protocol ping scan for host discovery

(IGMP) is a protocol that allows several devices to share one IP address so they can all receive the same data.

IGMP snooping is the process of listening to internet group management protocol(IGMP) network traffic to control the delivery of IP multicasting.



Ping Sweep Tools

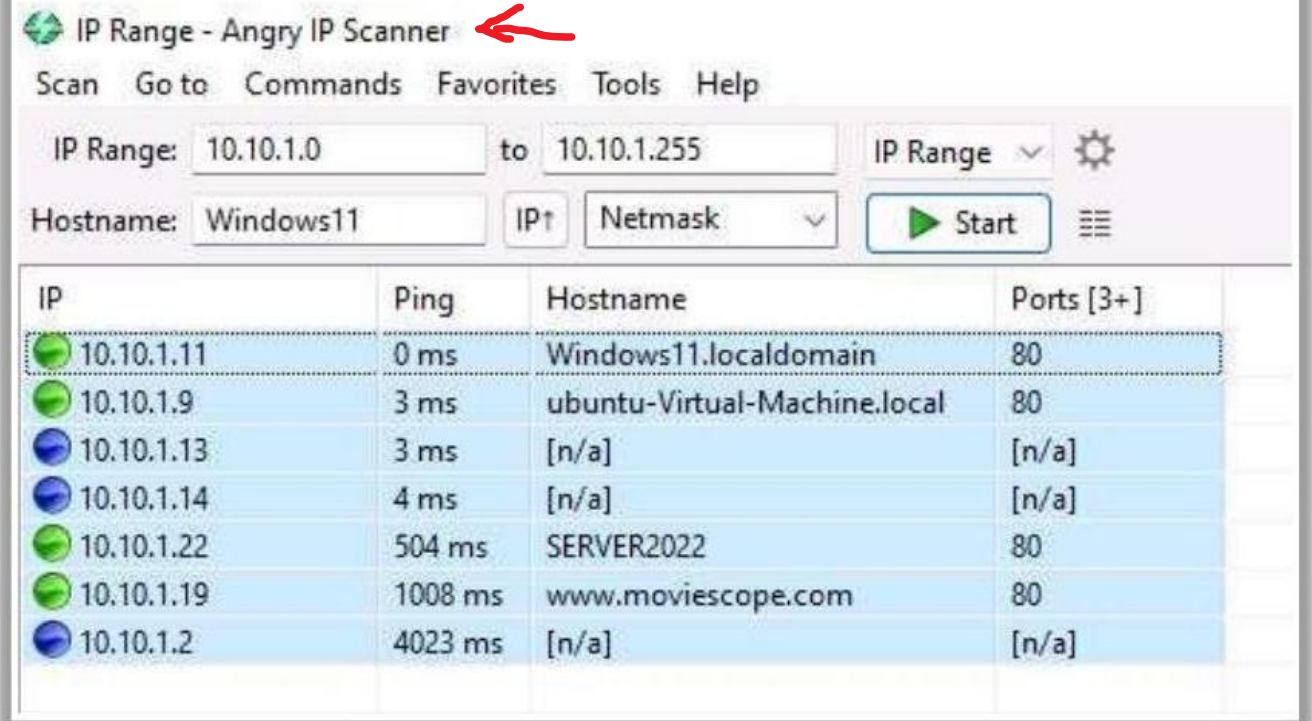
Lab.

Angry IP Scanner

Angry IP Scanner pings each IP address to check if any of these addresses are live. Then, it optionally resolves hostnames, **determines the MAC address**, **scans ports**, etc.

Ping Sweep Tools

- SolarWinds Engineer's Toolset (<https://www.solarwinds.com>)
- NetScanTools Pro (<https://www.netscantools.com>)
- Colasoft Ping Tool (<https://www.colasoft.com>)
- Visual Ping Tester (<http://www.pingtester.net>)
- OpUtils (<https://www.manageengine.com>)



IP Range - Angry IP Scanner

Scan Go to Commands Favorites Tools Help

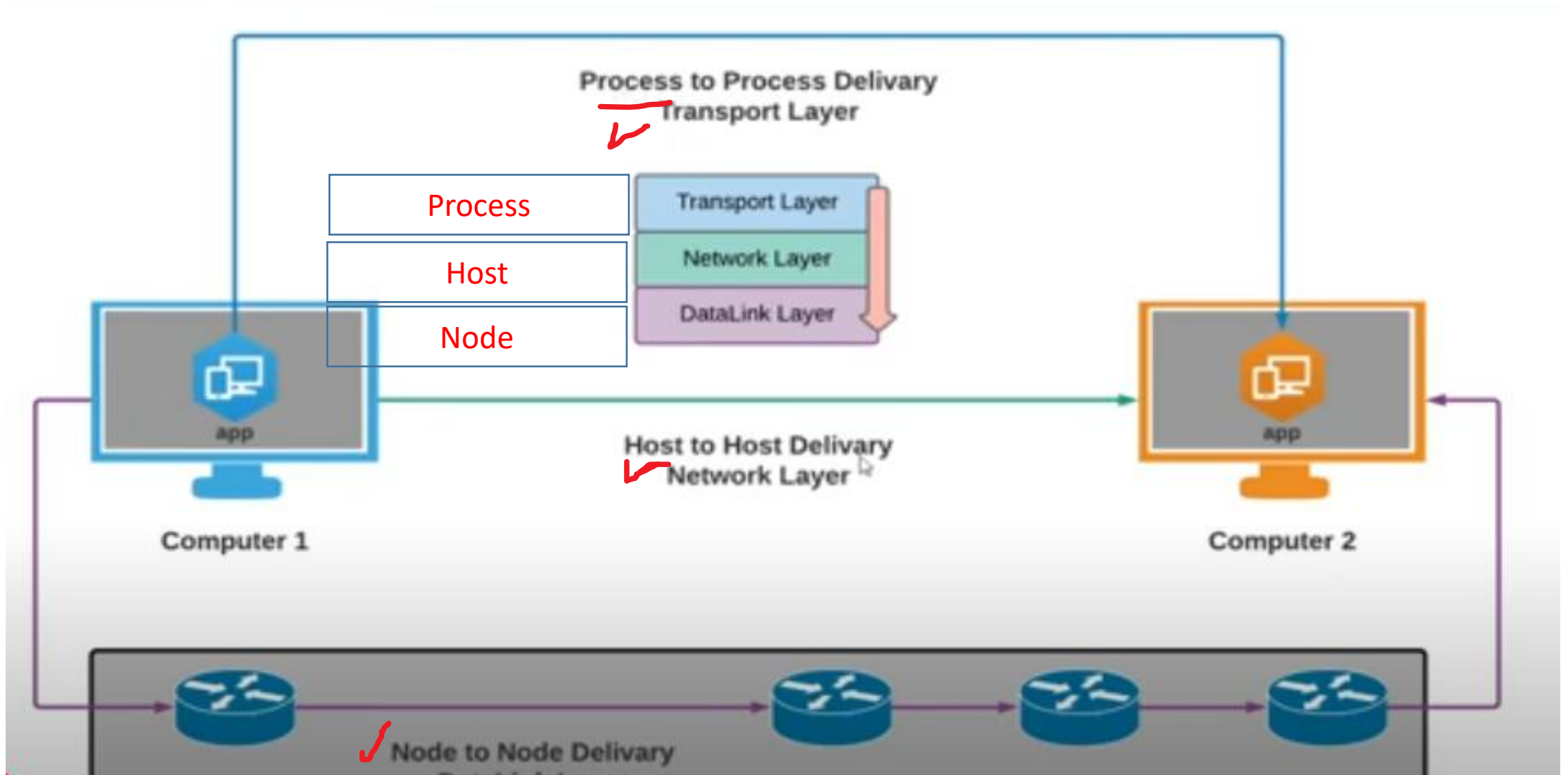
IP Range: 10.10.1.0 to 10.10.1.255 IP Range

Hostname: Windows11 IP Netmask Start

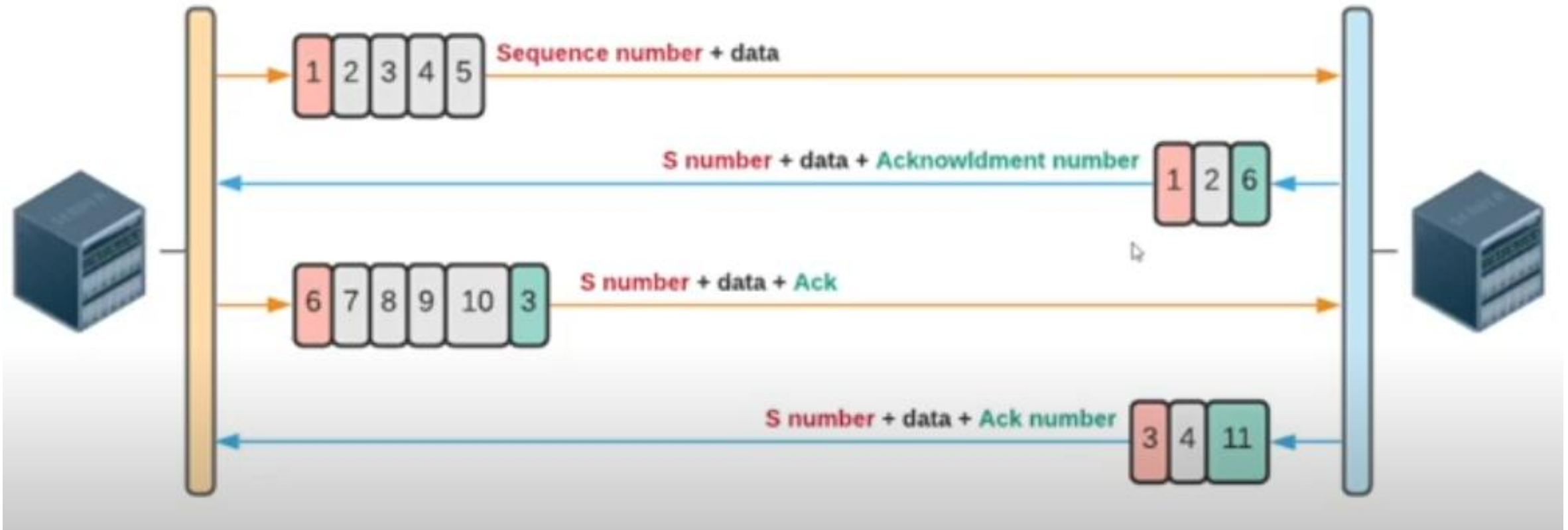
IP	Ping	Hostname	Ports [3+]
10.10.1.11	0 ms	Windows11.localdomain	80
10.10.1.9	3 ms	ubuntu-Virtual-Machine.local	80
10.10.1.13	3 ms	[n/a]	[n/a]
10.10.1.14	4 ms	[n/a]	[n/a]
10.10.1.22	504 ms	SERVER2022	80
10.10.1.19	1008 ms	www.moviescope.com	80
10.10.1.2	4023 ms	[n/a]	[n/a]

<https://www.angryip.org>

(TCP/UDP/SCTP) ping

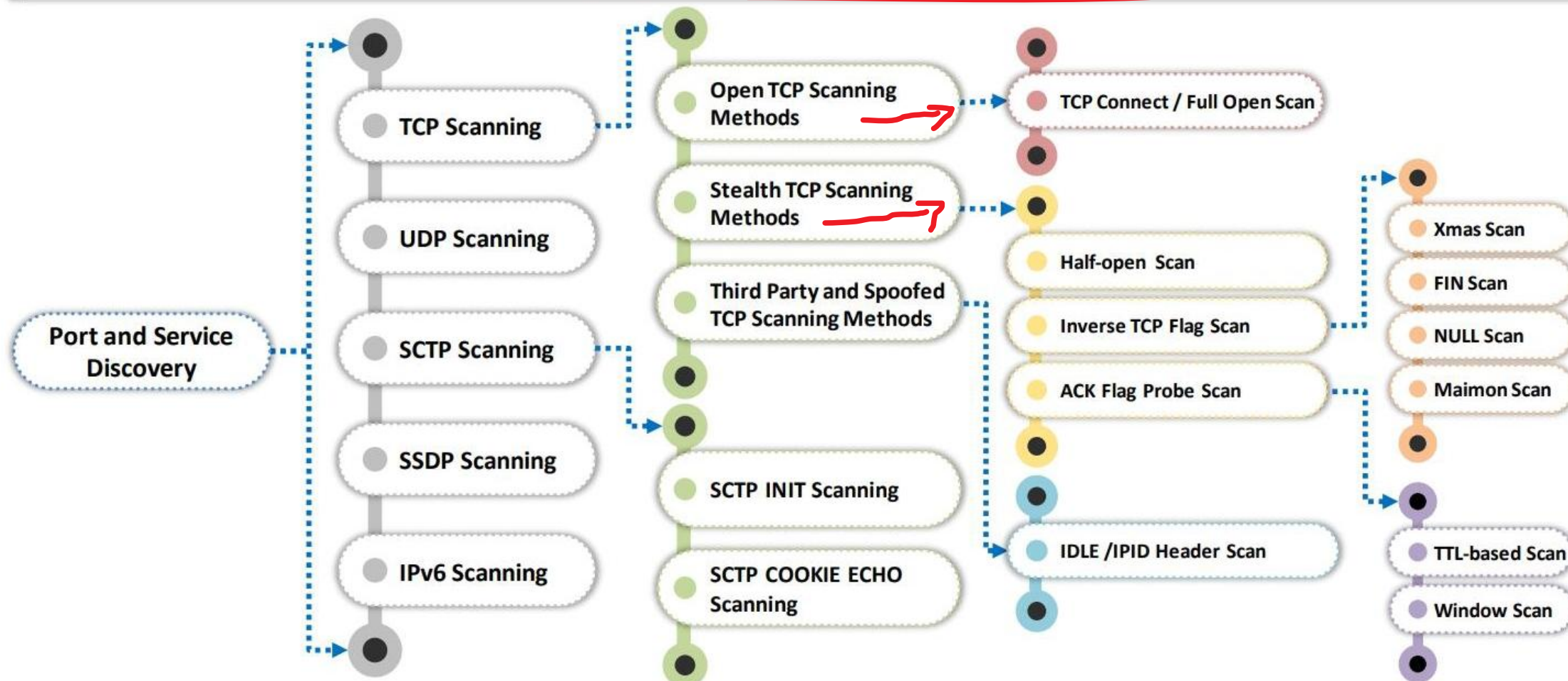


sequence number and acknowledgment number → error message control



Port Scanning Techniques

- The port scanning techniques are **categorized according to the type of protocol** used for communication



Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
TCP Connect/Full-Open Scan	<code>nmap -sT -v <Target IP Address></code>	SYN packets	✓ SYN+ACK packet response - Port is open ✓ RST packet response - Port is closed	✓ Does not require super-user privileges	✓ Easily detectable and filterable ✓ The logs in the target system disclose the connection
Stealth Scan (Half-Open Scan)	<code>nmap -sS -v <Target IP Address></code>	Single SYN packet	✓ SYN+ACK packet response - Port is open ✓ RST packet response - Port is closed	✓ Bypasses firewall rules and logging mechanisms	
Inverse TCP Flag Scan	<code>nmap -(-sF, -sN, -sX) -v <Target IP Address></code>	Probe packet (FIN/URG/PSH/NUL)	✓ No response - Port is open ✓ RST packet response - Port is closed	✓ Avoids many IDS and logging systems; highly stealthy	✓ Requires raw access to network sockets and super-user privileges ✓ Not effective against Microsoft Windows hosts, in particular
Xmas Scan	<code>nmap -sX -v <Target IP Address></code>	Probe packet (FIN + URG + PSH)	✓ No response - Port is open ✓ RST packet response - Port is closed	✓ Avoids IDS and the TCP three-way handshake	✓ Works only when systems are compliant with the RFC 793-based TCP/IP implementation ✓ Works on the Unix platform only ✓ Does not work against any current version of Microsoft Windows

Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
FIN Scan	nmap -sF -v <Target IP Address>	Probe packet (FIN)	✓ No response - Port is open ✓ RST packet response - Port is closed	✓ Probe packets enabled with TCP flags can pass through filters undetected, depending on the security mechanisms installed ✓ Works only when systems are compliant with the RFC 793-based TCP/IP implementation	✓ Effective only when used with Unix-based OSes ✓ Does not work against any current version of Microsoft Windows
NULL Scan	nmap -sN -v <Target IP Address>	Probe packet (NULL)	✓ No response - Port is open ✓ RST packet response - Port is closed		
TCP Maimon Scan	nmap -sM -v <Target IP Address>	Probe packet (FIN/ACK)	✓ No response - Port is open ✓ ICMP unreachable error response - Port is filtered ✓ RST packet response - Port is closed		

Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
ACK Flag Probe Scan	<code>nmap -sA -v <Target IP Address></code>	ACK probe packets	✓ No response - Port is filtered (stateful firewall is present) ✓ RST packet response - Port is not filtered (no firewall is present)	✓ Can evade IDS in most cases ✓ Helps in checking the filtering systems of target networks	✓ Extremely slow and can exploit only older OSes with vulnerable BSD-derived TCP/IP stacks
TTL-Based ACK Flag Probe Scan	<code>nmap -sA -ttl 100 -v <target IP address></code>	ACK probe packets (several thousands) to different TCP ports	✓ RST packet response - Port is open (TTL value on a port < 64) ✓ RST packet response - Port is closed (TTL value on a port > 64)		
Window-Based ACK Flag Probe Scan	<code>nmap -sA -sW -v <target IP address></code>	ACK probe packets (several thousands) to different TCP ports	✓ RST packet response - Port is open (WINDOW value on a port is non-zero) ✓ ICMP unreachable error response - Port is filtered ✓ RST packet response - Port is closed (WINDOW value on a port is zero)		
IDLE/IPID Header Scan	<code>nmap -Pn -p- -sl <Zombie Hostname> <Target Hostname></code>	SYN packet	✓ SYN+ACK packet response - Port is open ✓ RST packet response - Port is closed	✓ Offers the complete blind scanning of a remote host	✓ Requires the identification of sequence numbers of the zombie host

Port Scanning Techniques (Cont'd)

Scanning Technique	Nmap Command	Request	Response	Advantages	Disadvantages
UDP Scan	nmap -sU -v <Target IP Address>	UDP packet	✓ No response - Port is open ✓ ICMP unreachable error response - Port is closed	✓ Less informal with regard to an open port because there is no overhead of a TCP handshake ✓ Microsoft-based OSes do not usually implement any ICMP rate limiting; hence, this scan operates very efficiently on Windows-based devices	✓ Slow because it limits the ICMP error message rate as a form of compensation to machines that apply RFC 1812 section 4.3.2.8 ✓ A remote host will require access to the raw ICMP socket to distinguish closed ports from unreachable ports ✓ Requires privileged access
SCTP INIT Scan	nmap -sY -v <Target IP Address>	INIT chunk	✓ INIT+ACK chunk - Port is open ✓ ICMP unreachable exception - Port is filtered ✓ ABORT chunk - Port is closed	✓ An INIT scan is performed quickly by scanning thousands of ports per second on a fast network not obstructed by a firewall, offering a strong sense of security ✓ Can clearly differentiate between various ports such as open, closed, and filtered states	
SCTP COOKIE ECHO Scan	nmap -sZ -v <Target IP Address>	COOKIE ECHO chunk	✓ No response - Port is open ✓ ABORT chunk - Port is closed	✓ The COOKIE ECHO chunk is not blocked by non-stateful firewall rule sets. ✓ Only an advanced IDS can detect an SCTP COOKIE ECHO scan	✓ Cannot differentiate clearly between open and filtered ports, showing the output as open filtered in both cases

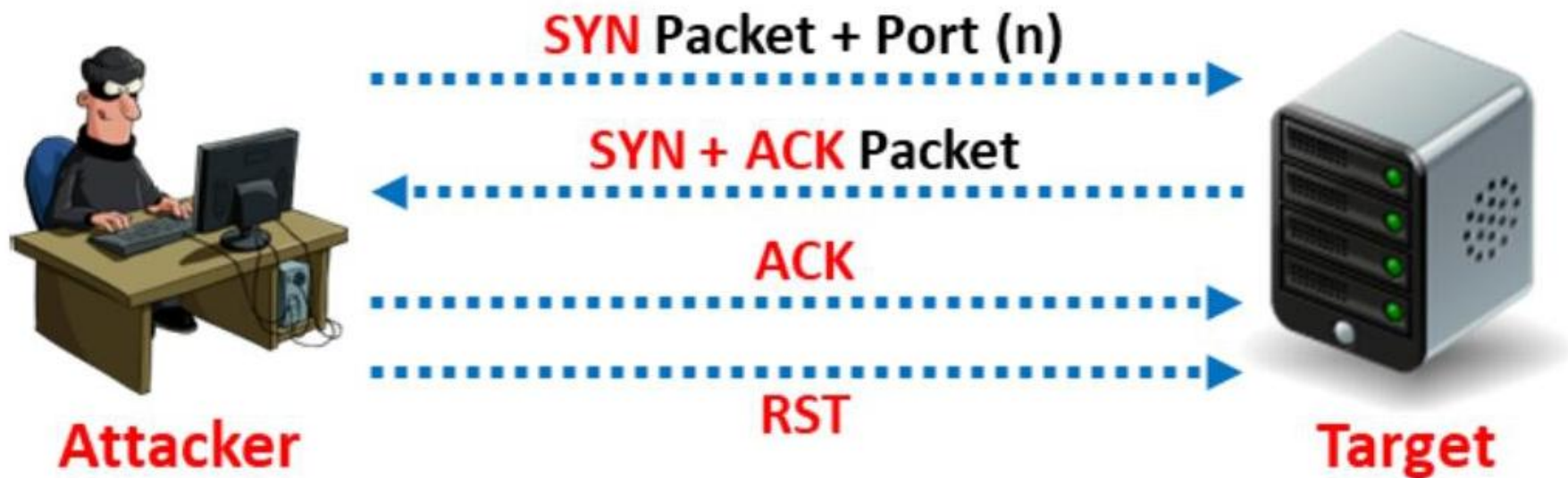


Figure 3.33: Scan result when a port is open

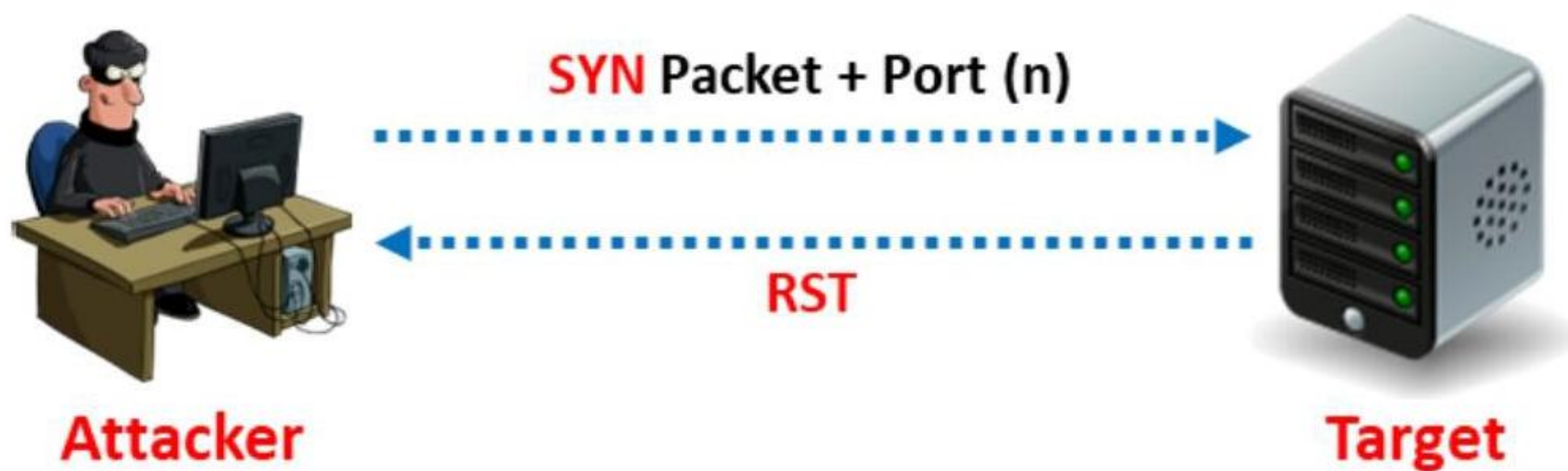


Figure 3.34: Scan result when a port is closed

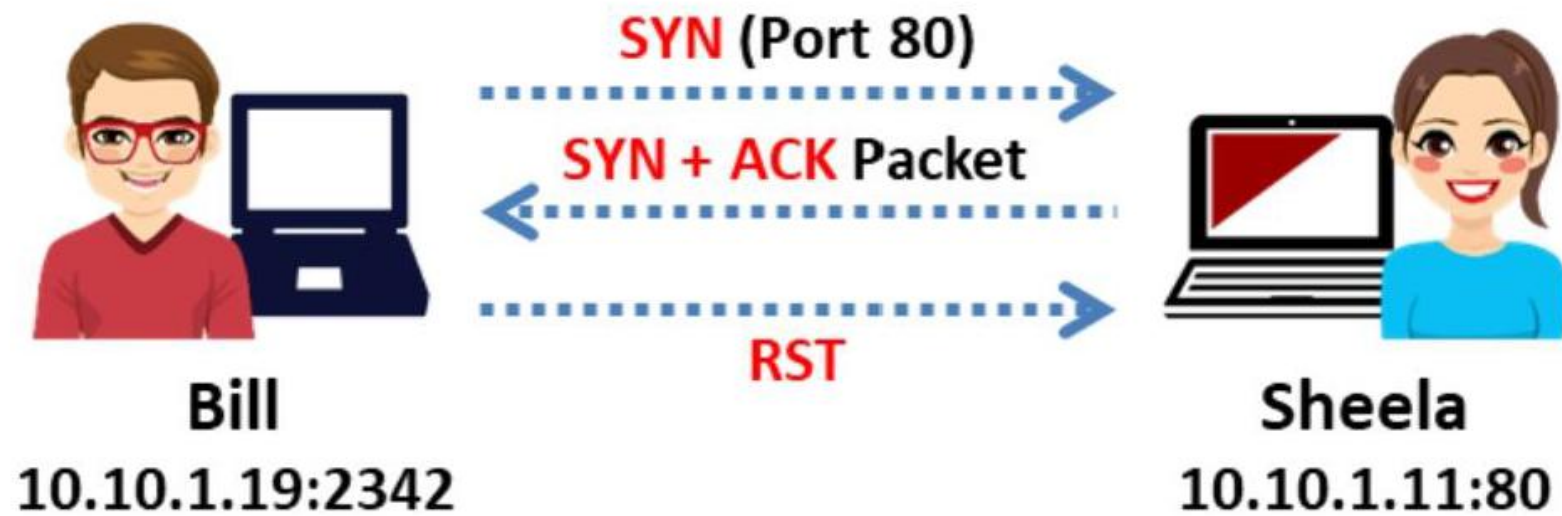


Figure 3.36: Port is open

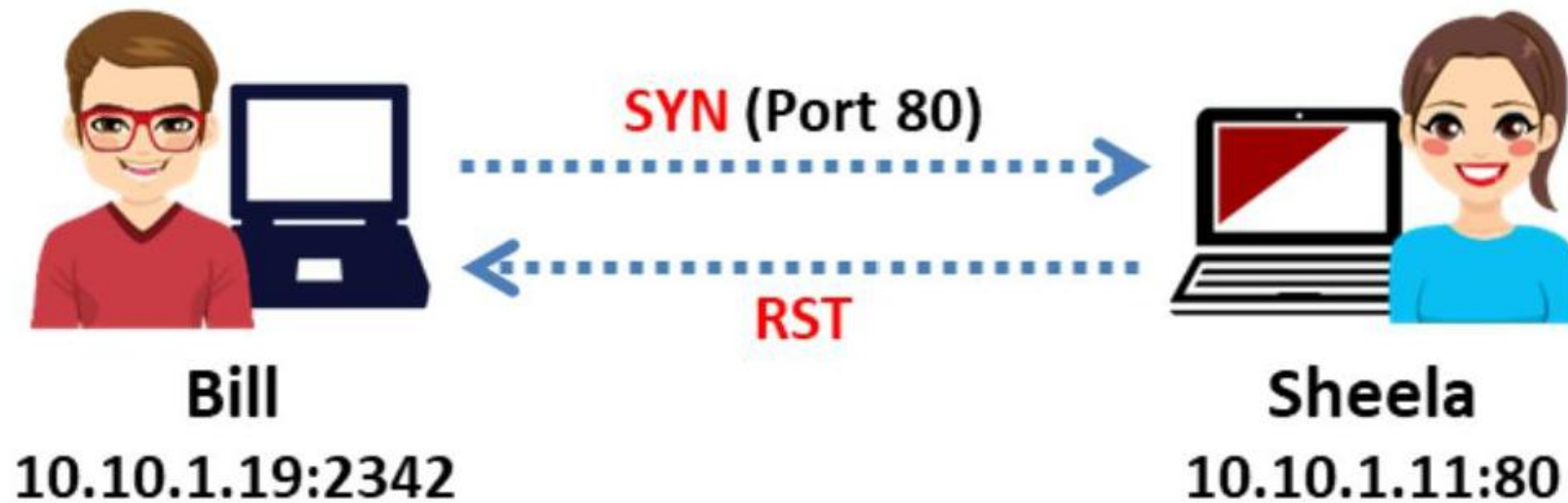


Figure 3.37: Port is closed

Attackers send TCP probe packets with a TCP flag (FIN, URG, PSH) set or with no flags,

- No response means the port is open.
- RST means the port is closed.

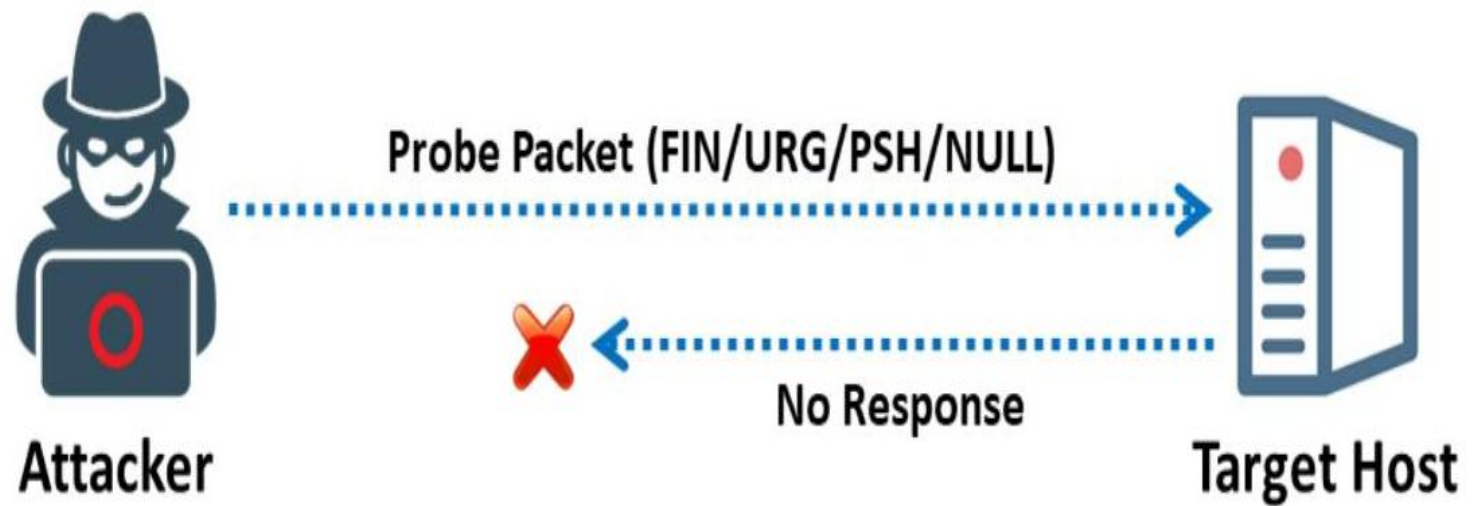


Figure 3.39: Inverse TCP flag scan when port is open

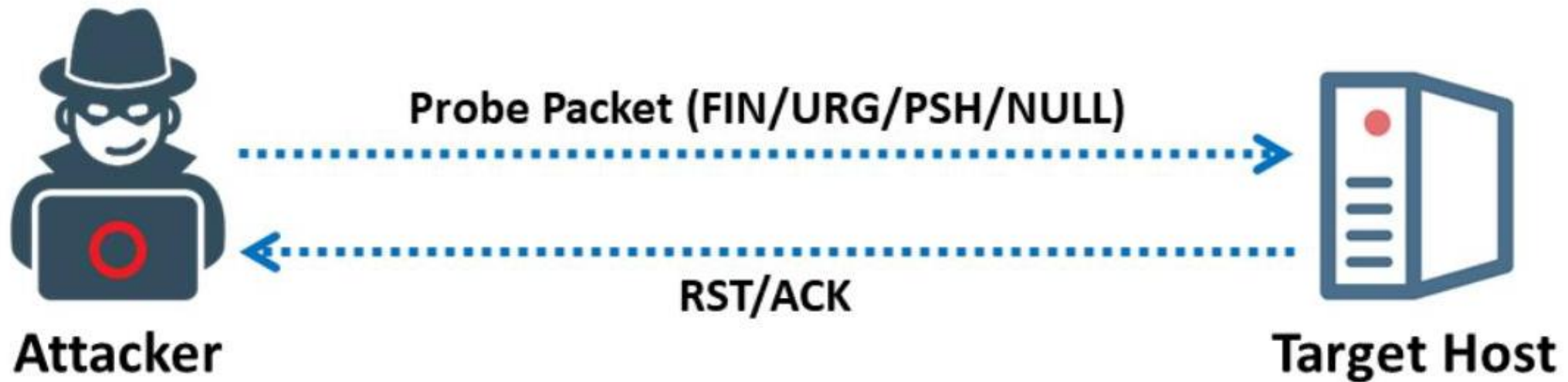


Figure 3.40: Inverse TCP flag scan when port is closed

RST and responses
In the same time because
TTL will drop a packet if
Its not finish the hops in
Specific time.

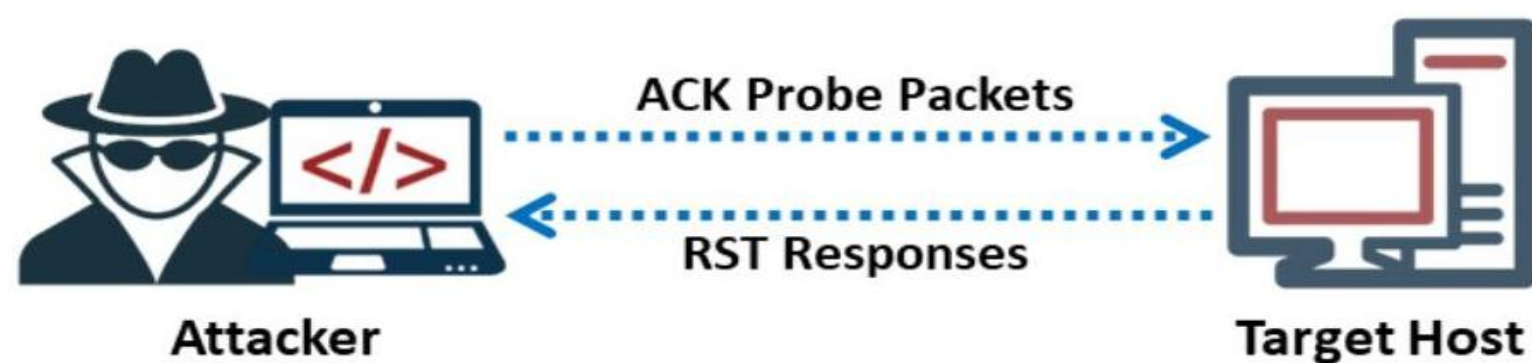


Figure 3.48: TTL-based ACK flag probe scanning

```
1: host 10.2.2.11 port 20: F:RST -> ttl: 80 win: 0
2: host 10.2.2.11 port 21: F:RST -> ttl: 80 win: 0
3: host 10.2.2.11 port 22: F:RST -> ttl: 50 win: 0
4: host 10.2.2.11 port 23: F:RST -> ttl: 80 win: 0
```

Figure 3.49: Screenshot showing the open port based on the TTL value of the RST packet

```
1: host 10.2.2.12 port 20: F:RST -> ttl: 64 win: 0
2: host 10.2.2.12 port 21: F:RST -> ttl: 64 win: 0
3: host 10.2.2.12 port 22: F:RST -> ttl: 64 win: 512
4: host 10.2.2.12 port 23: F:RST -> ttl: 64 win: 0
```

Figure 3.51: Screenshot showing the open port based on the window value of the RST packet

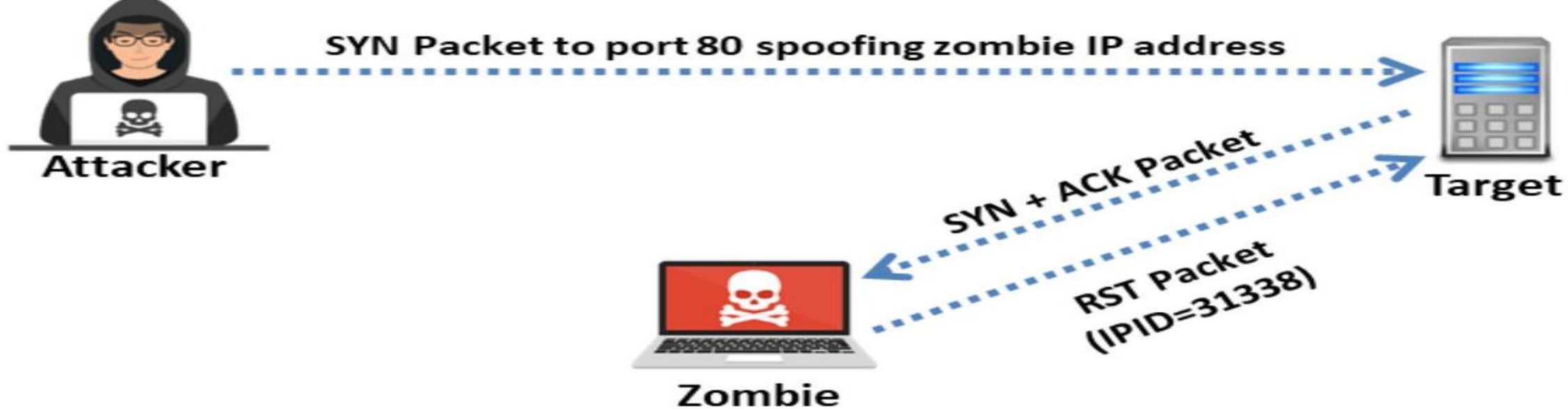


Figure 3.60: Port is open



Figure 3.61: Port is closed

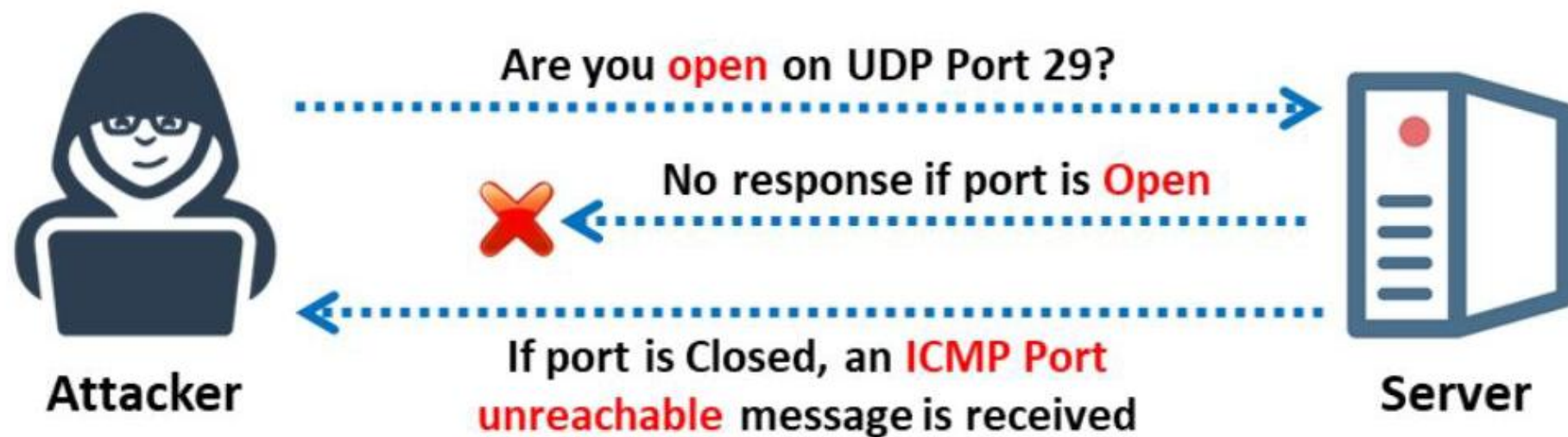


Figure 3.63: UDP scanning

Nmap Scan Time Reduction Techniques

■ In Nmap, **performance** and **accuracy** can be achieved by reducing the scan timing

Scan Time Reduction Techniques

1 Omit Non-critical Tests

ex,. Skip the port scan (-sn) when you only need to determine what hosts are online.

4 Upgrade Nmap

2 Optimize Timing Parameters

5 Execute Concurrent Nmap Instances
[nmap-services](#) and [nmap-os-db](#)

3 Separate and Optimize UDP Scans

6 Scan from a Favorable Network Location

7 Increase Available Bandwidth and CPU Time

<https://nmap.org/book/reduce-scantime.html>

LO#05: Demonstrate Various Scanning Techniques for OS Discovery

OS Discovery/Banner Grabbing

- Banner grabbing or OS fingerprinting is the method used to **determine the operating system running on a remote target system**. There are two types of banner grabbing: active and passive
- Identifying the OS used on the target host allows an attacker to **figure out the vulnerabilities possessed by the system** and the exploits that might work on a system to further **carry out additional attacks**

Active Banner Grabbing

- **Specially crafted packets** are sent to the remote OS and the responses are noted
- The responses are then compared with a database to **determine the OS**
- Responses from different OSes vary due to differences in the **TCP/IP stack implementation**



Passive Banner Grabbing

- **Banner grabbing from error messages**
Error messages provide information such as the type of server, type of OS, and SSL tool used by the target remote system.
- **Sniffing the network traffic**
Capturing and analyzing packets from the target enables an attacker to determine the OS used by the remote system.
- **Banner grabbing from page extensions**
Looking for an extension in the URL may assist in determining the application's version.

Example: .aspx => IIS server and Windows platform

Note: We will discuss passive banner grabbing in later modules.

How to Identify Target System OS

- Attackers can identify the OS running on the target machine by looking at the **Time To Live (TTL)** and **TCP window size** in the IP header of the first packet in a TCP session
- Sniff/capture the response** generated from the target machine using packet-sniffing tools like Wireshark and observe the TTL and TCP window size fields

Possible OS is Windows

Possible OS is Linux

OS Discovery using Wireshark

<https://www.wireshark.org>

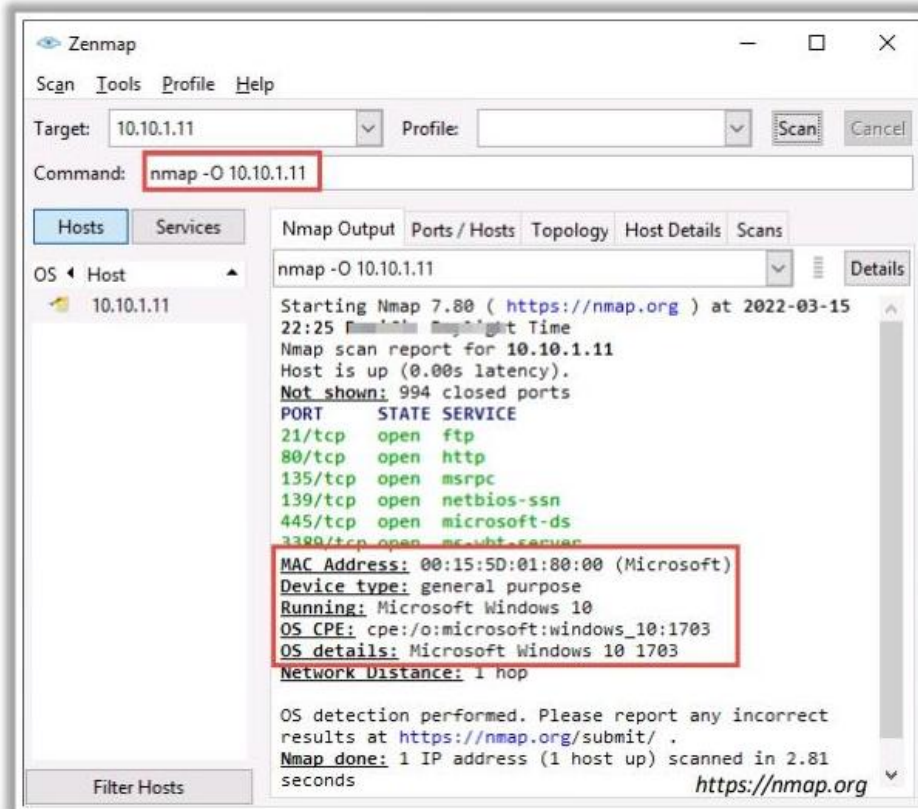
Window size values for OS

Operating System	Time To Live	TCP Window Size
Linux	64	5840
FreeBSD	64	65535
OpenBSD	255	16384
Windows	128	65,535 bytes to 1 Gigabyte
Cisco Routers	255	4128
Solaris	255	8760
AIX	255	16384



OS Discovery using Nmap and Unicornscan

- In **Nmap**, the **-O** option is used to perform OS discovery, providing OS details of the target machine



- In **Unicornscan**, the OS of the target machine can be identified by **observing the TTL values** in the acquired scan result

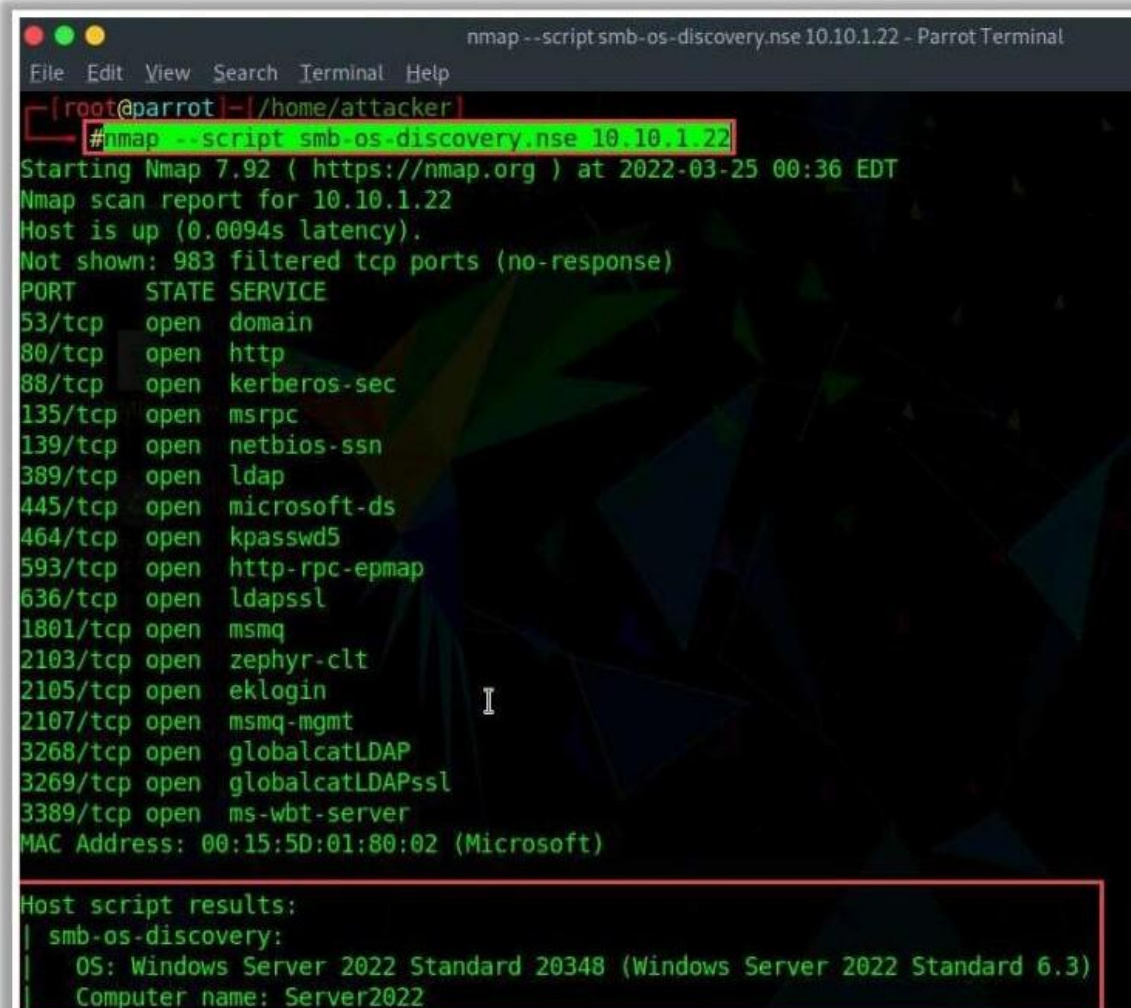


Possible OS is Windows

<https://sourceforge.net>

OS Discovery using Nmap Script Engine

- Nmap script engine (NSE) can be used to **automate** a wide variety of **networking tasks** by allowing the users to **write and share scripts**
- Attackers use various scripts in the Nmap Script Engine to **perform OS discovery** on the target machine
- For example, in Nmap, **smb-os-discovery** is an inbuilt script that can be used for **collecting OS information** on the target machine **through the SMB protocol**
- In Zenmap, the **-sC** option or **-script** option is used to activate the NSE scripts



```
nmap --script smb-os-discovery.nse 10.10.1.22 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot:~/home/attacker]
#nmap -sC 10.10.1.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-25 00:36 EDT
Nmap scan report for 10.10.1.22
Host is up (0.0094s latency).
Not shown: 983 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
1801/tcp  open  msmq
2103/tcp  open  zephyr-clt
2105/tcp  open  eklogin
2107/tcp  open  msmq-mgmt
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
MAC Address: 00:15:5D:01:80:02 (Microsoft)

Host script results:
| smb-os-discovery:
|   OS: Windows Server 2022 Standard 20348 (Windows Server 2022 Standard 6.3)
|   Computer name: Server2022
```

<https://nmap.org>

OS Discovery using IPv6 Fingerprinting

- IPv6 Fingerprinting can be used to **identify the OS running** on the target machine



- IPv6 fingerprinting has the **same functionality** as that of IPv4



- The difference between IPv6 and IPv4 fingerprinting is that the IPv6 uses several **additional advanced probes specific to IPv6** along with a **separate OS detection engine that is specialized for IPv6**



- In Zenmap, the **-6 option** and **-O option** are used to perform OS discovery using the IPv6 fingerprinting method

🌐 Syntax: **# nmap -6 -O <target>**



LO#06: Demonstrate Various Techniques for Scanning Beyond IDS and Firewall

IDS/Firewall Evasion Techniques

- Though firewalls and IDSs can prevent malicious traffic (packets) from entering a network, attackers can manage to **send intended packets to the target** by **evading an IDS or firewall** through the following techniques:

1 Packet Fragmentation

2 Source Routing

3 Source Port Manipulation

4 IP Address Decoy

5 IP Address Spoofing

6 MAC Address Spoofing

7 Creating Custom Packets

8 Randomizing Host Order and Sending Bad Checksums

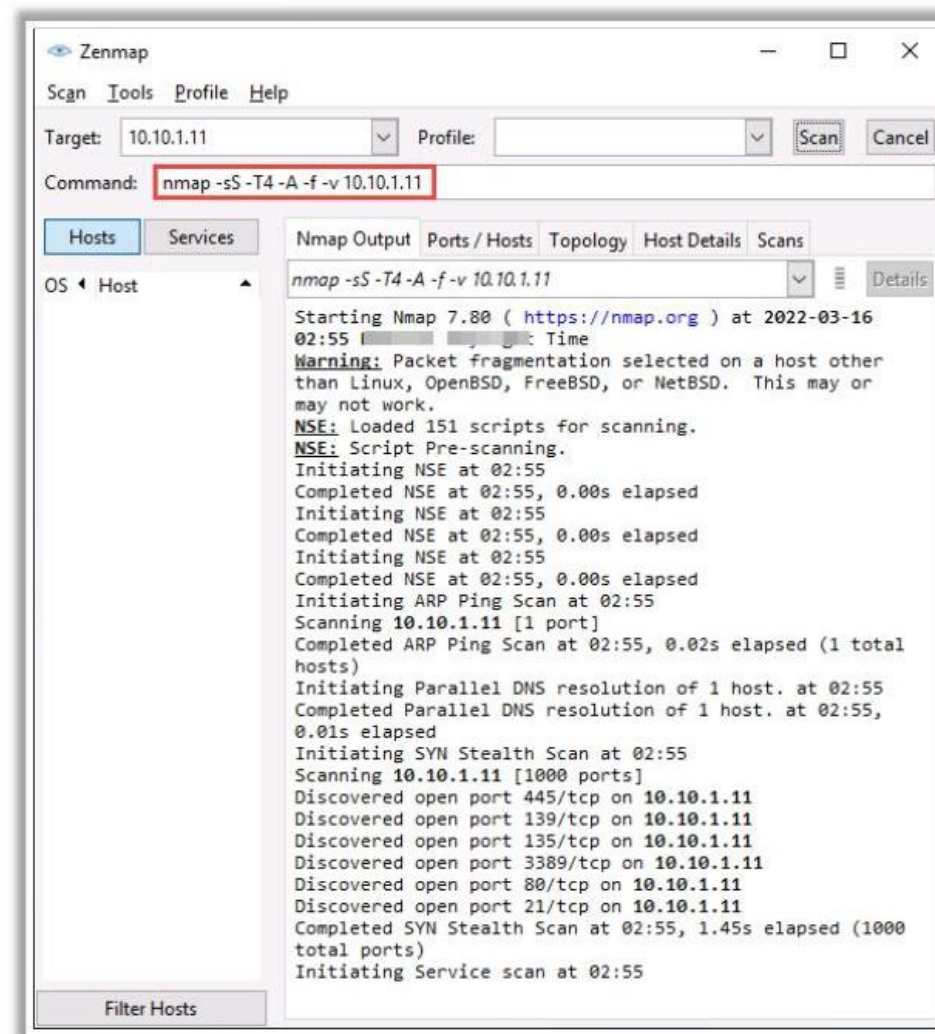
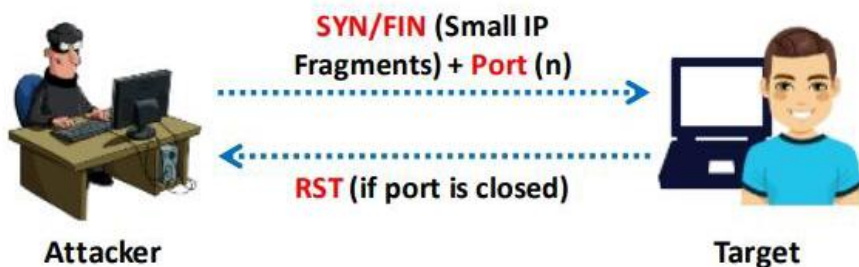
9 Proxy Servers

10 Anonymizers

Packet Fragmentation

- Packet fragmentation refers to the **splitting of a probe packet into several smaller packets** (fragments) while sending it to a network
- It is not a new scanning method but a **modification** of the previous techniques
- The **TCP header** is split into several packets so that the packet filters are not able to detect what the packets are intended to do

SYN/FIN Scanning Using IP Fragments

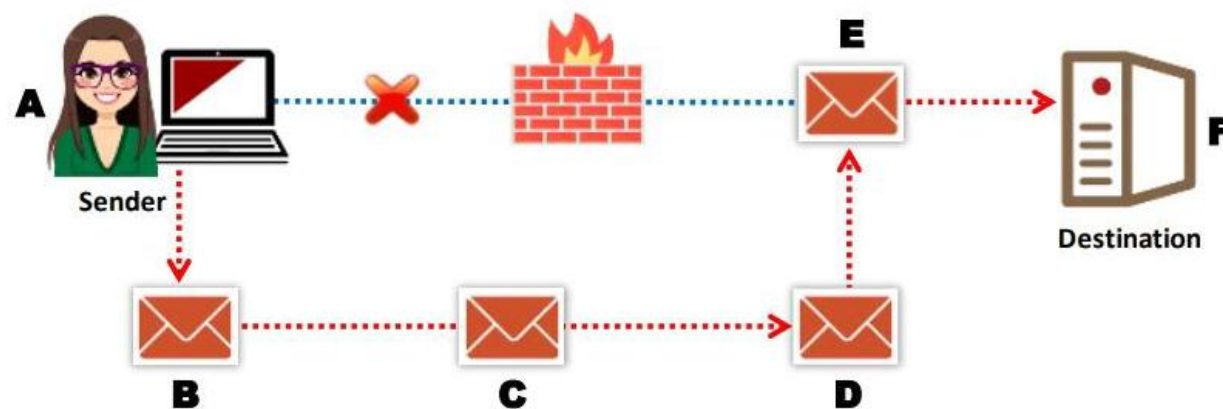


Source Routing

- As the packet travels through the nodes in the network, each **router examines** the destination IP address and **chooses the next hop** to direct the packet to the destination
- Source routing refers to sending a packet to the intended destination with a partially or completely **specified route** (without firewall-/IDS-configured routers) in order to evade an IDS or firewall
- In source routing, the **attacker** makes some or all of these decisions on the router

- Bypassing Security Controls:
- Reconnaissance:
- Manipulating Traffic:

This figure shows source routing, where the originator dictates the eventual route of the traffic



Source Port Manipulation

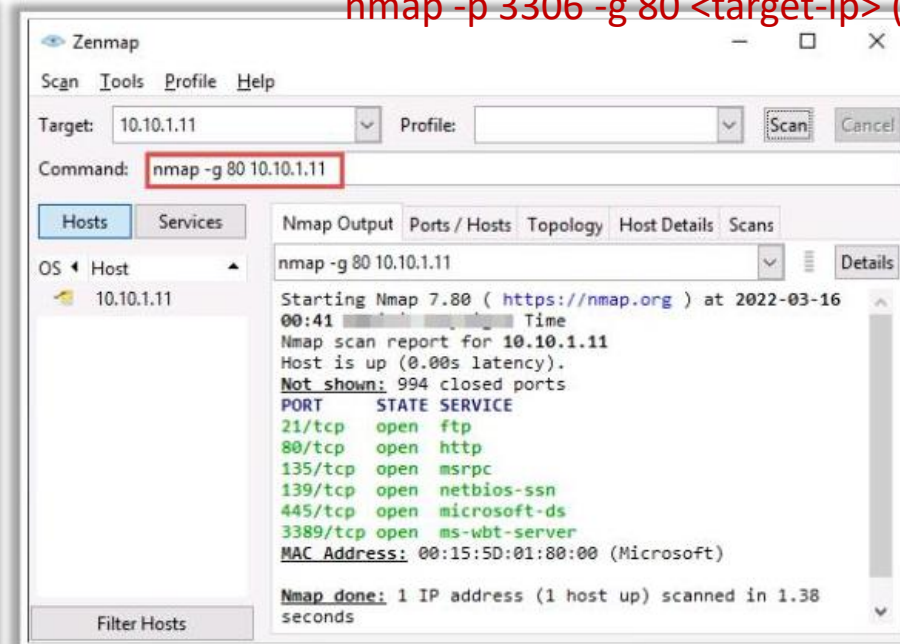
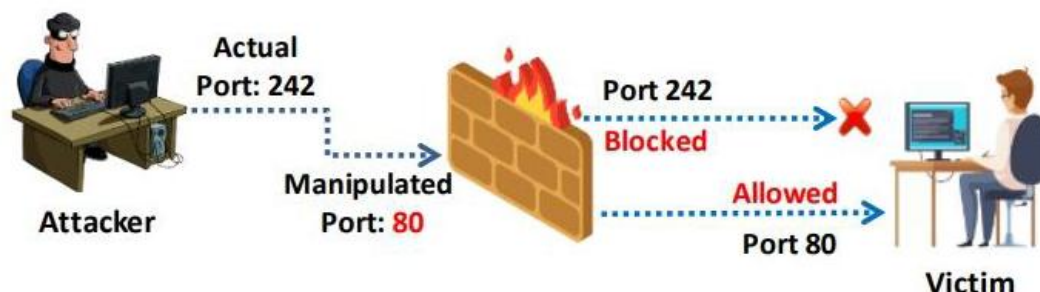
- Source port manipulation refers to **manipulating actual port numbers with common port numbers** in order to evade an IDS or firewall
- It occurs when a firewall is **configured to allow packets** from well-known ports like HTTP, DNS, FTP, etc.
- Nmap** uses the **-g** or **--source-port** options to perform source port manipulation

Scenario:

`nmap -p 3306 <target-ip> (close)`

`nmap -p 3306 -g 80 <target-ip> (re)`

Firewall allowing manipulated Port 80 to the victim from attacker



<https://nmap.org>

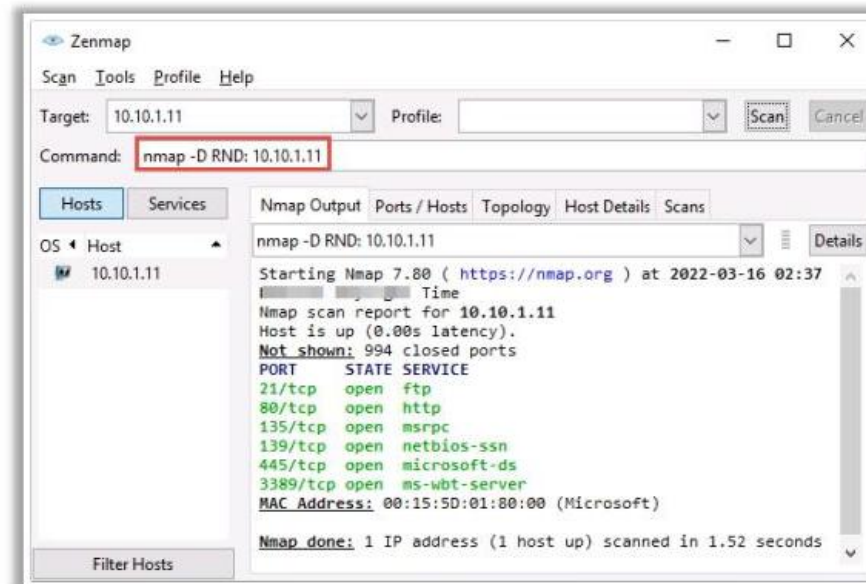
IP Address Decoy

- IP address decoy technique refers to **generating or manually specifying the IP addresses of decoys** in order to evade an IDS or firewall
- It appears to the target that the **decoys as well as the host(s)** are scanning the network
- This technique makes it **difficult for the IDS or firewall to determine** which IP address was actually scanning the network and which IP addresses were decoys

Decoy Scanning using Nmap

Nmap has two options for decoy scanning:

- `nmap -D RND:10 [target]`
(Generates a random number of decoys)
- `nmap -D decoy1,decoy2,decoy3, . . etc. [target]`
(Manually specify the IP addresses of the decoys)



<https://nmap.org>

IP Address Spoofing

- IP spoofing refers to **changing the source IP addresses** so that the attack **appears to be coming from someone else**
- When the victim replies to the address, it goes back to the **spoofed address** rather than the **attacker's real address**
- Attackers modify the **address information** in the IP packet header and the source address bits field in order to bypass the IDS or firewall

IP spoofing using Hping3:

```
Hping3 www.certifiedhacker.com -a 7.7.7.7
```

nmap -sS -S <spoofed_ip> <target>

ex: nmap -sS -S 192.168.1.100 -e eth0 -Pn 192.168.1.1

- 192.168.1.100 is the spoofed IP address.
- eth0 is the network interface being used.
- Pn skips host discovery.
- 192.168.1.1 is the target IP address



Note: You will not be able to complete the three-way handshake and open a successful TCP connection with spoofed IP addresses

MAC Address Spoofing

- The MAC address spoofing technique involves spoofing a MAC address with the MAC address of a legitimate user on the network.
- Attackers use the **--spoof-mac** Nmap option to set a specific MAC address for the packets to evade firewalls.

```
nmap -sT -Pn --spoof-mac 0 10.10.1.11 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#nmap -sT -Pn --spoof-mac 0 10.10.1.11
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-16 02:56 EDT
Spoofing MAC address DF:FB:47:17:14:72 (No registered vendor)
You have specified some options that require raw socket access.
These options will not be honored for TCP Connect scan.
Nmap scan report for 10.10.1.11
Host is up (0.039s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds
[root@parrot]~/home/attacker
#
```

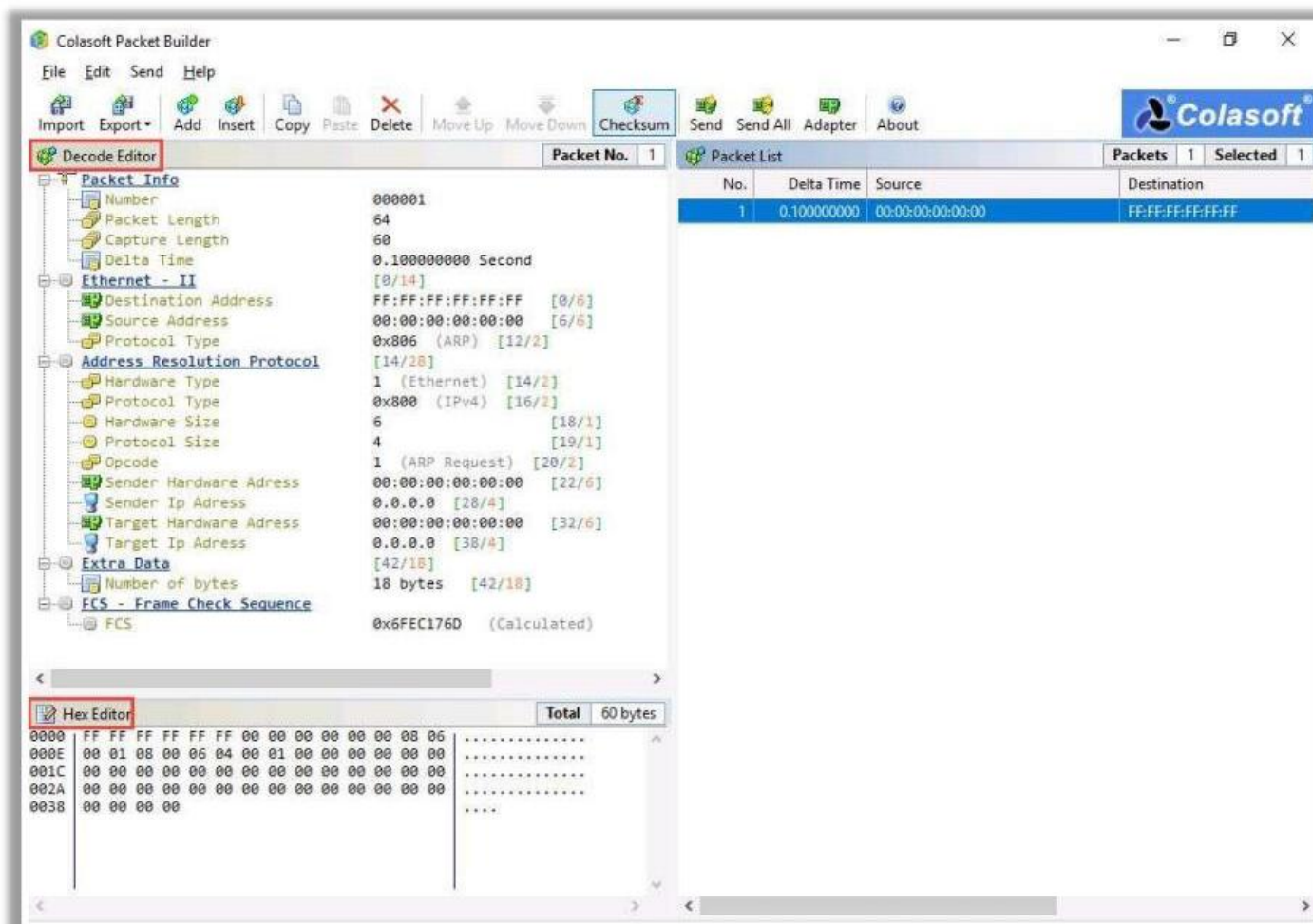
```
nmap -sT -Pn --spoof-mac Dell 10.10.1.11 - Parrot Terminal
File Edit View Search Terminal Help
[root@parrot]~/home/attacker
#nmap -sT -Pn --spoof-mac Dell 10.10.1.11
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-16 02:58 EDT
Spoofing MAC address 00:00:97:82:FE:32 (Dell EMC)
You have specified some options that require raw socket access.
These options will not be honored for TCP Connect scan.
Nmap scan report for 10.10.1.11
Host is up (0.044s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server

Nmap done: 1 IP address (1 host up) scanned in 0.58 seconds
[root@parrot]~/home/attacker
#
```

Creating Custom Packets

Creating Custom Packets by using Packet Crafting Tools

- Attackers **create custom TCP packets** using various packet crafting tools like **Colasoft Packet Builder**, **NetScanTools Pro**, etc. to scan a target beyond a firewall

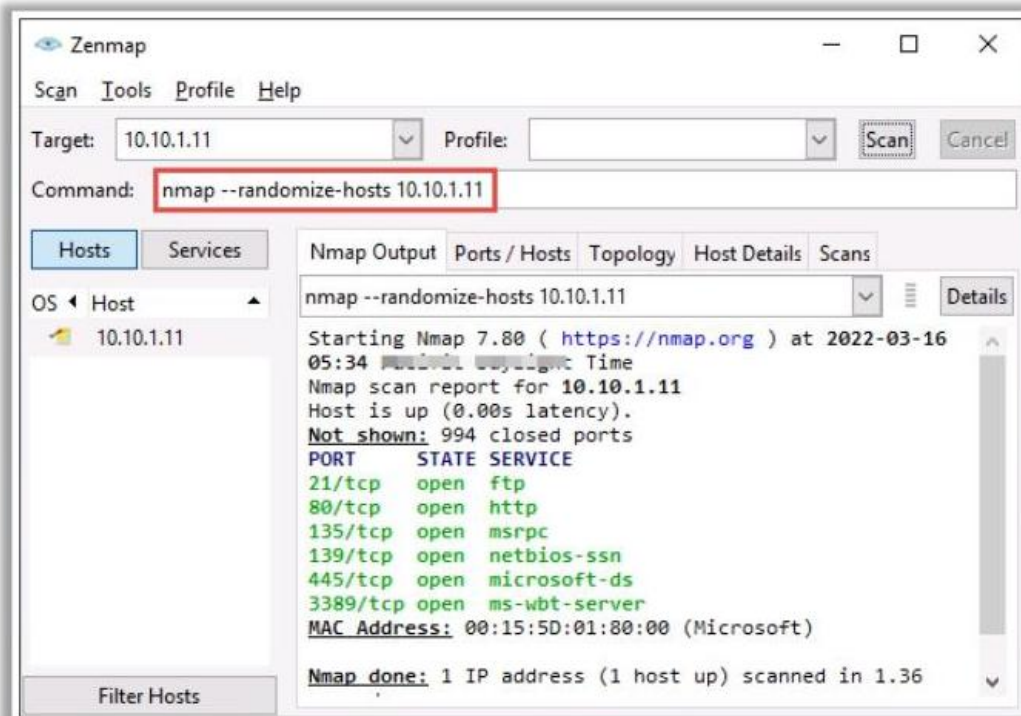


<https://www.colasoft.com>

Randomizing Host Order and Sending Bad Checksums

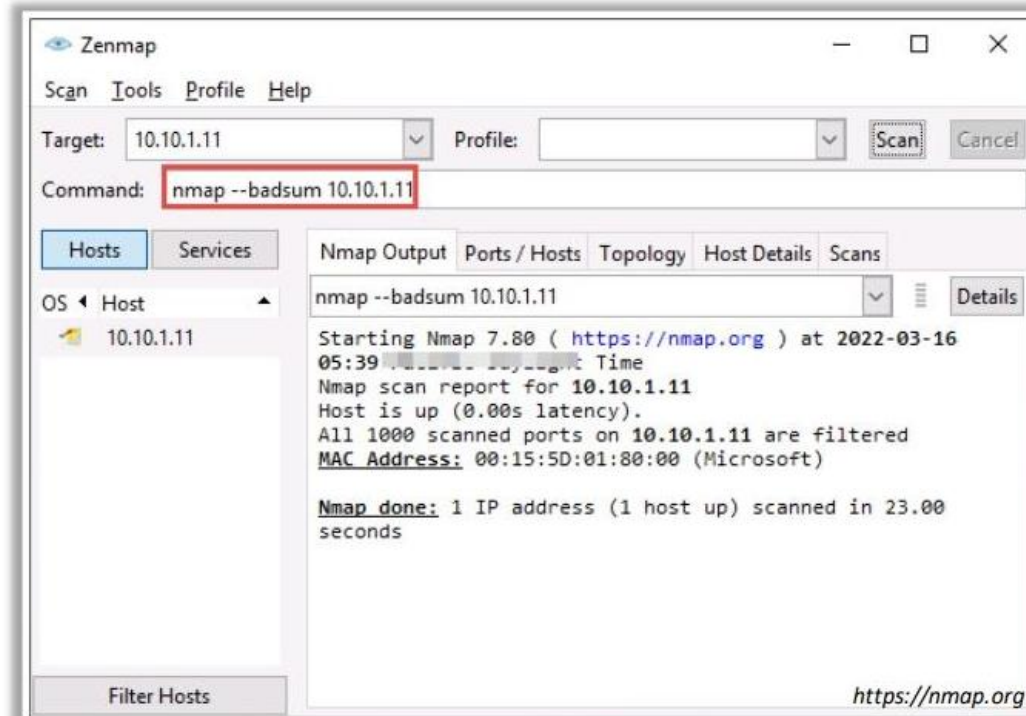
Randomizing Host Order

- Attackers **scan the number of hosts** in the target network **in random order** to scan an intended target that is behind a firewall



Sending Bad Checksums

- Attackers send packets with bad or bogus **TCP/UDP checksums** to the intended target to avoid certain firewall rulesets



Proxy Servers

A proxy server is an application that can **serve as an intermediary** for connecting with other computers

Why Attackers Use Proxy Servers?

- 1 To hide the actual source of a scan and **evade certain IDS/firewall restrictions**
- 2 To **mask the actual source** of an attack by impersonating the fake source address of the proxy
- 3 To **remotely access intranets** and other **website resources** that are normally restricted
- 4 To **interrupt all requests** sent by a user and transmit them to a third destination such that victims can only identify the proxy server address
- 5 To chain **multiple proxy servers** to avoid detection

Note: A search in **Google** will list thousands of **free proxy servers**

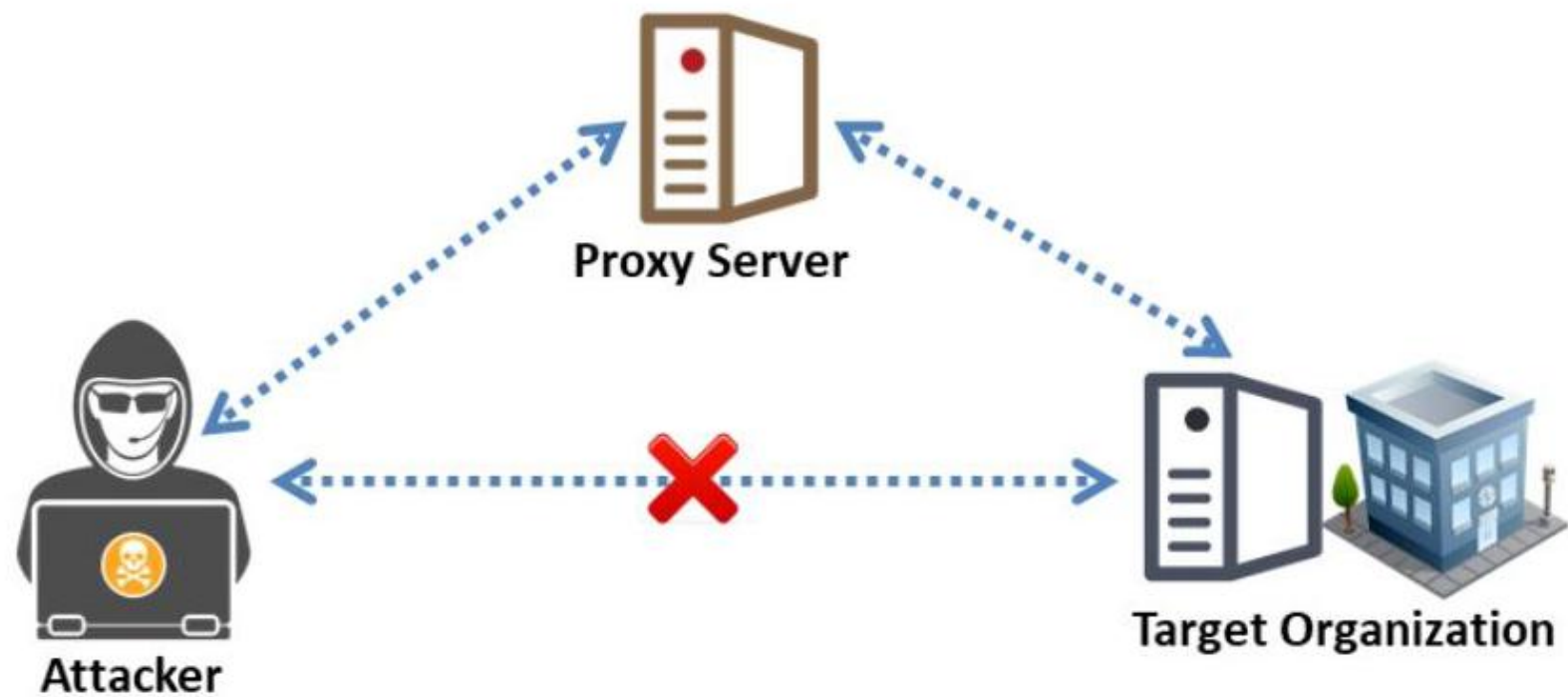
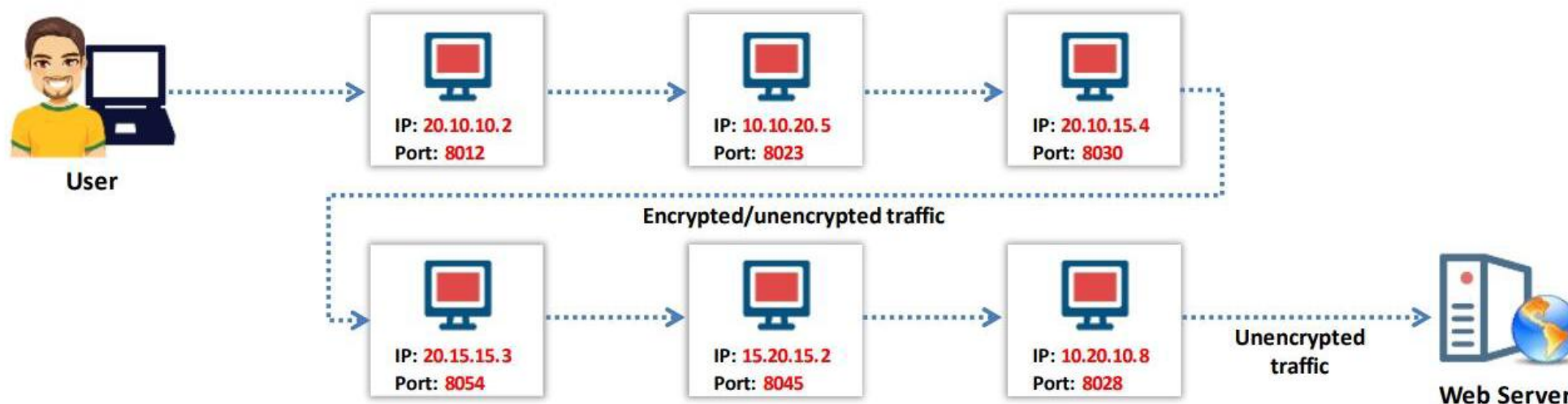


Figure 3.95: Attacker using a proxy server for connecting to the target

Proxy Chaining

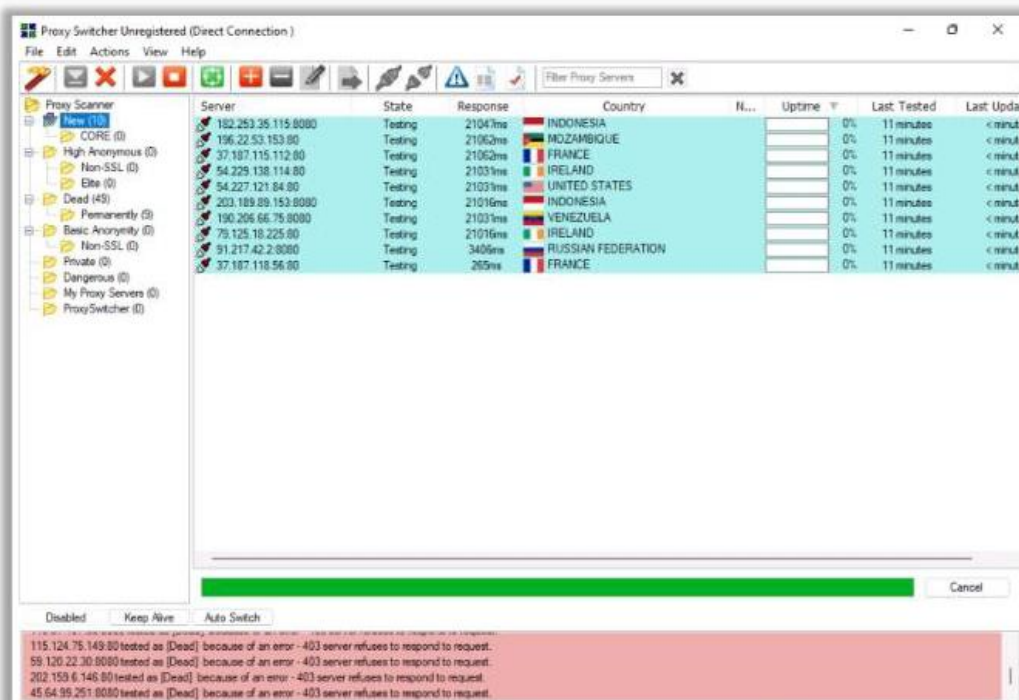
- 1 User **requests a resource** from the destination
- 2 Proxy client at the user's system connects to a **proxy server** and passes the request to proxy server
- 3 The proxy server **strips the user's identification information** and passes the request to next proxy server
- 4 This process is repeated by all the proxy servers in the **chain**
- 5 At the end, the **unencrypted request** is passed to the web server



Proxy Tools

Proxy Switcher

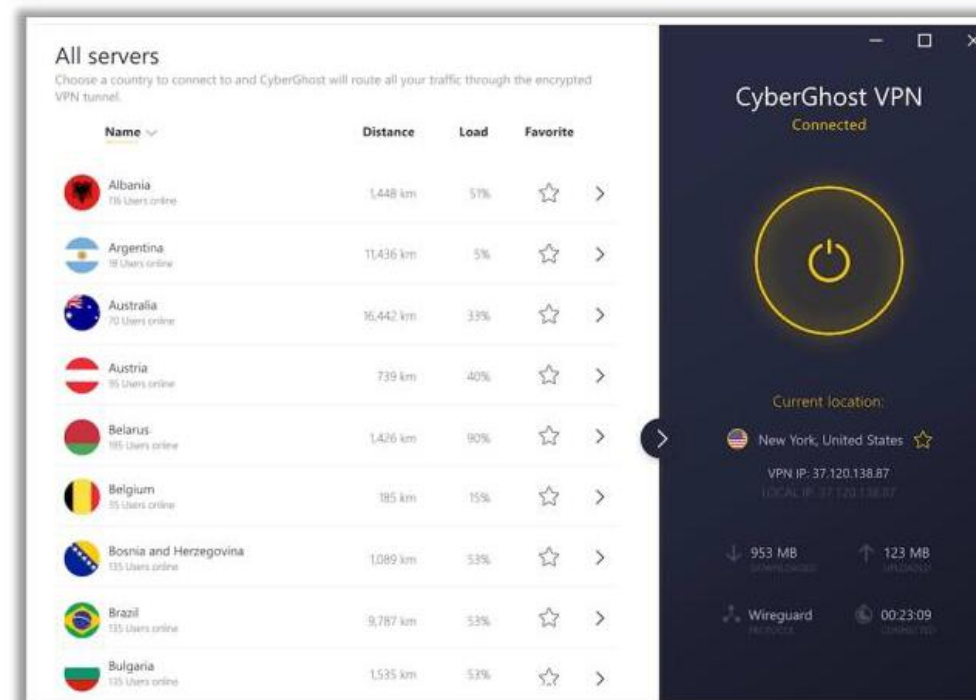
Proxy Switcher allows you to **surf anonymously on the Internet** without disclosing your IP address



<https://www.proxyswitcher.com>

CyberGhost VPN

CyberGhost VPN **hides your IP** and replaces it with one of your choice, thus allowing you to surf anonymously



<https://www.cyberghostvpn.com>

Other Proxy Tools:

Burp Suite

<https://www.portswigger.net>

Tor

<https://www.torproject.org>

CCProxy

<https://www.youngzsoft.net>

Hotspot Shield

<https://www.hotspotshield.com>

Anonymizers

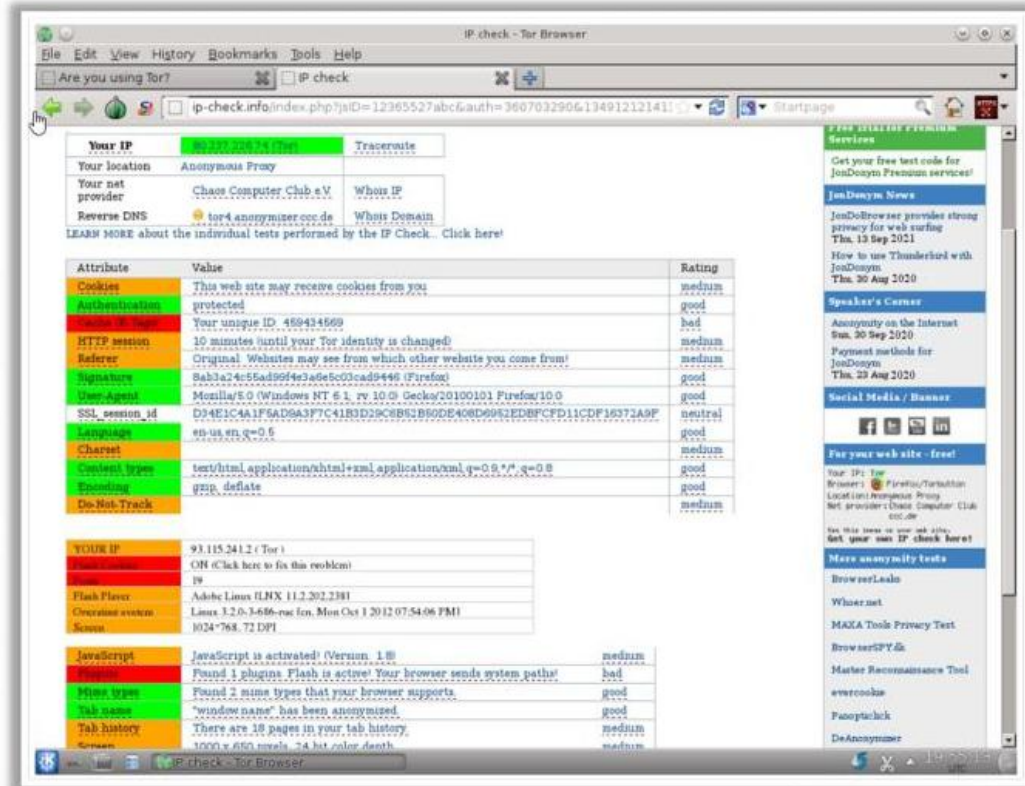
- An anonymizer **removes** all identity information from the user's computer while the user surfs the Internet
- Anonymizers make activity on the Internet **untraceable**
- Anonymizers allow you to **bypass Internet** censors

Why use an Anonymizer?

- 1 Privacy and anonymity
- 2 Protection against online attacks
- 3 Access restricted content
- 4 Bypass IDS and Firewall rules

Whonix

Whonix is a **desktop operating system** designed for advanced security and privacy

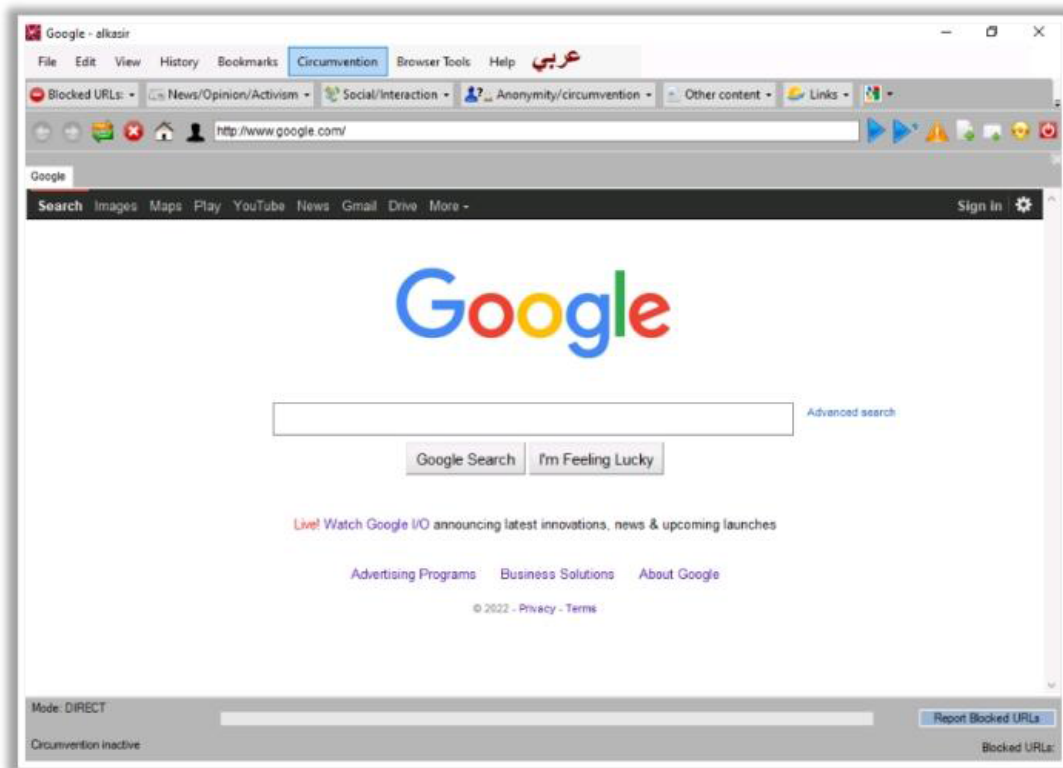


<https://www.whonix.org>

Censorship Circumvention Tools: Alkasir and Tails

Alkasir

Alkasir is a **cross-platform**, open-source, and robust website censorship circumvention tool that also **maps censorship patterns** around the world



<https://github.com>

Tails

Tails is a **live operating system** that a user can start on any computer from a DVD, USB stick, or SD card



<https://tails.boum.org>

LO#07: Explain Network Scanning Countermeasures

Port Scanning Countermeasures

1 Configure **firewall** and **IDS rules** to detect and block probes

2 Run **port scanning tools** against hosts on the network to determine whether the firewall properly **detects port scanning activity**

3 Ensure that the mechanisms used for **routing** and **filtering** at the routers and firewalls, respectively, **cannot be bypassed** using a particular source port or source routing methods

4 Ensure that the **router**, **IDS**, and **firewall firmware** are updated to their latest releases/versions

5 Use a **custom rule set** to lock down the network and block **unwanted ports** at the firewall

6 Filter all **ICMP messages** (i.e., inbound ICMP message types and outbound ICMP type 3 unreachable messages) at the **firewalls and routers**

7 Perform **TCP and UDP scanning** along with ICMP probes against your organization's IP address space to **check the network configuration and its available ports**

8 Ensure that **anti-scanning** and **anti-spoofing** rules are properly configured

Banner Grabbing Countermeasures

Disabling or Changing Banner

- Display **false banners** to mislead or deceive attackers
- **Turn off unnecessary services** on the network host to limit the disclosure of information
- Use server masking tools to disable or change banner information
- For Apache 2.x with the **mod_headers** module, use a directive in the **httpd.conf** file to change the banner information header and set the server as **New Server Name**
- Alternatively, change the **ServerSignature** line to **ServerSignature Off** in the **httpd.conf** file

Hiding File Extensions from Web Pages

- File extensions reveal information about the **underlying server technology** that an attacker can utilize to launch attacks
- Hide file extensions to **mask the web technologies**
- Replace **application mappings** such as .asp with .htm or .foo, etc. to disguise the identities of servers
- Apache users can use **mod_negotiation** directives
- IIS users can use tools such as **PageXchanger** to manage the file extensions
- ✓ **It is preferable to not use file extensions at all**

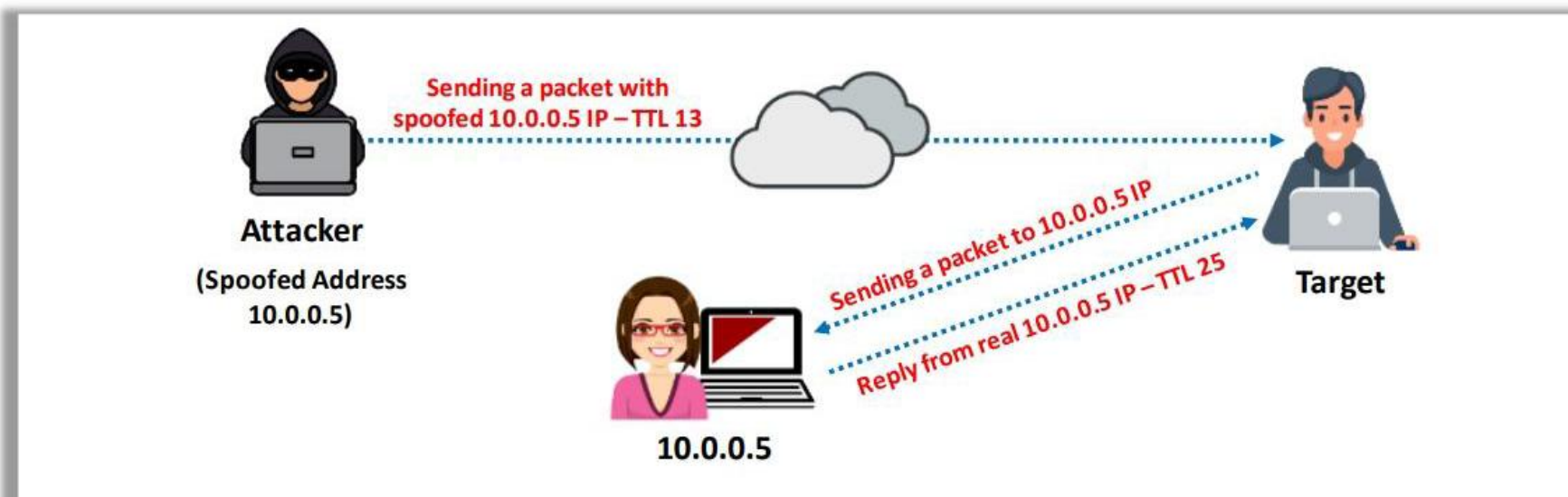
IP Spoofing Detection Techniques: Direct TTL Probes

1

Send a packet to the host of a suspected spoofed packet that triggers a reply and compare the TTL with that of the suspected packet; if the **TTL in the reply is not the same** as the packet being checked, this implies that it is a spoofed packet

2

This technique is successful when the attacker is in a **different subnet** from that of the victim



Note: Normal traffic from one host can contrast TTLs depending on traffic patterns

IP Spoofing Detection Techniques: IP Identification Number

01

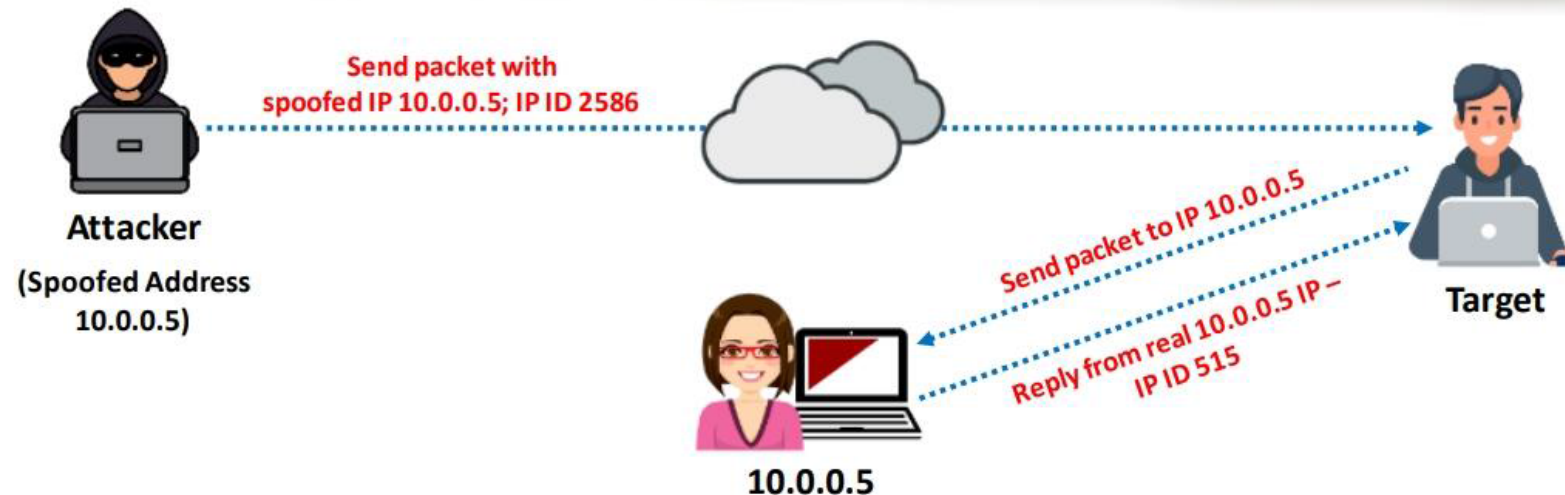
Send a probe to the host of a suspected spoofed traffic that triggers a reply and **compare the IPID** with the suspected traffic

02

If the IPIDs are **not close in value** to the packet being checked, then the suspected traffic is spoofed

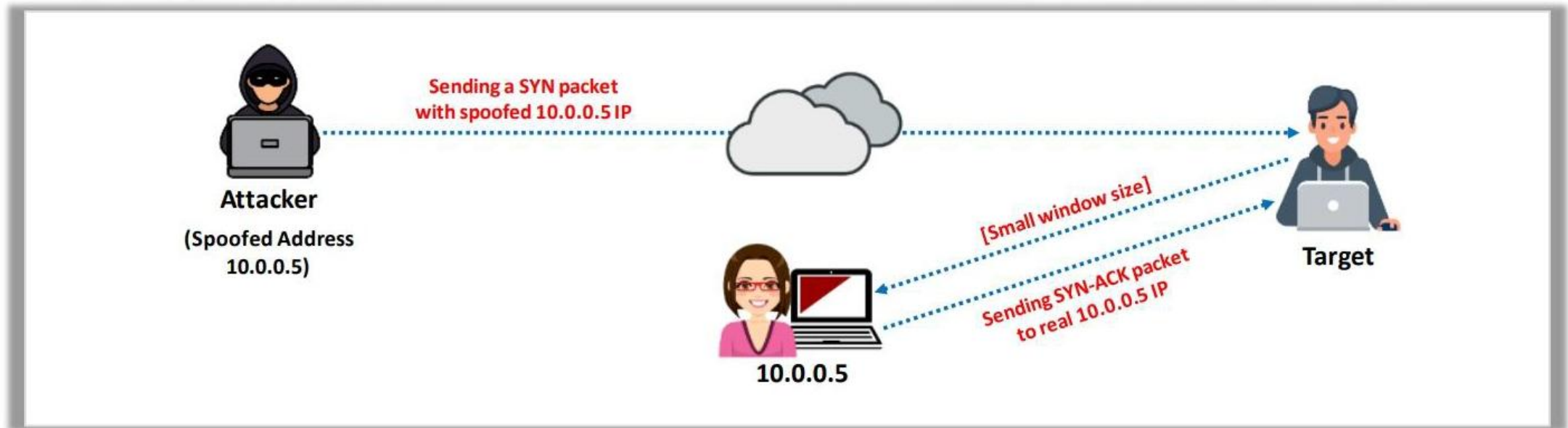
03

This technique is considered reliable even if the attacker is in the **same subnet**



IP Spoofing Detection Techniques: TCP Flow Control Method

- Attackers sending spoofed TCP packets will not receive the **target's SYN-ACK packets**
- Therefore, attackers cannot respond to a change in the congestion window size
- When received traffic continues after a window size is exhausted, the **packets are most likely spoofed**



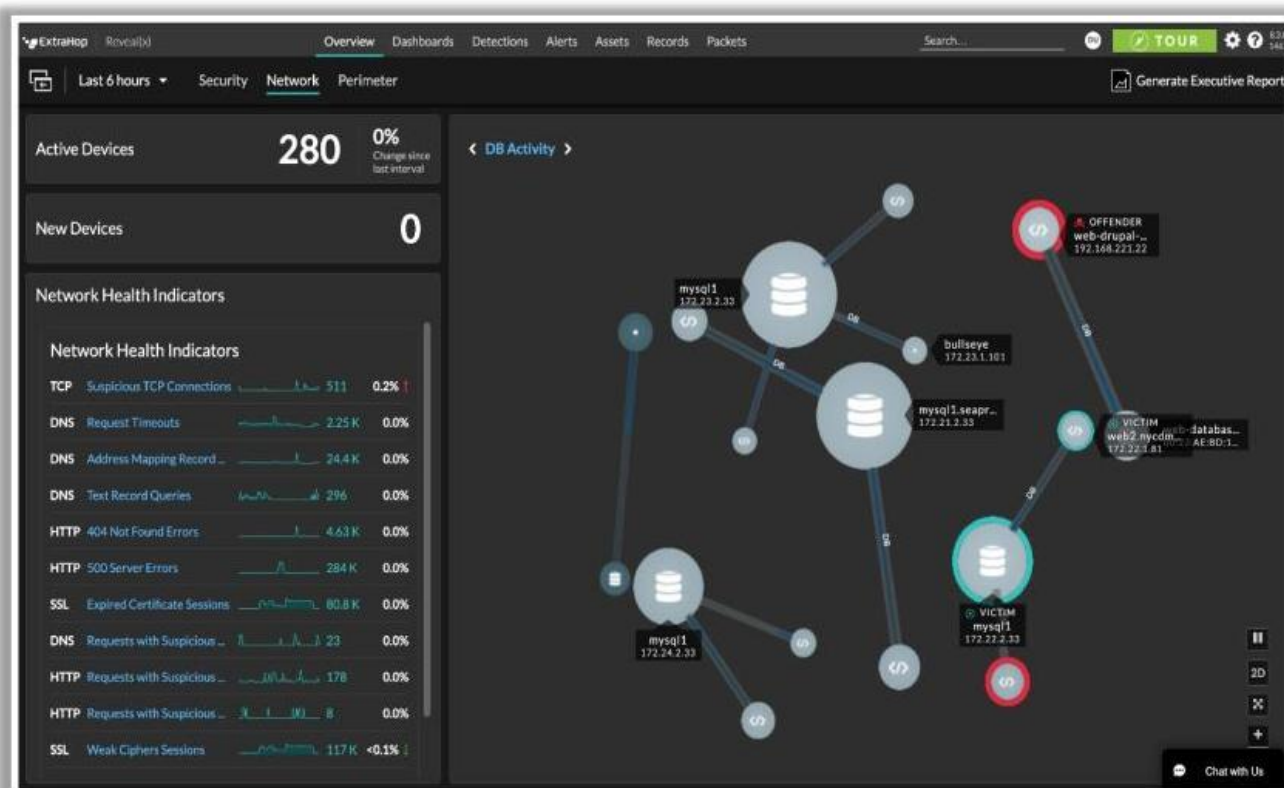
IP Spoofing Countermeasures

- 1 **Encrypt all the network traffic** using cryptographic network protocols such as IPsec, TLS, SSH, and HTTPS
- 2 **Use multiple firewalls** to provide a multi-layered depth of protection
- 3 Do not rely on **IP-based authentication**
- 4 **Use a random initial sequence number** to prevent IP spoofing attacks based on sequence number spoofing
- 5 **Ingress Filtering**: Use routers and firewalls at your network perimeter to filter incoming packets that appear to come from an internal IP address
- 6 **Egress Filtering**: Filter all outgoing packets with an invalid local IP address as the source address

Scanning Detection and Prevention Tools

ExtraHop

It provides complete visibility, real-time **detection**, and **intelligent response** to malicious network scanning



<https://www.extrahop.com>



Splunk Enterprise Security

<https://www.splunk.com>



Scanlogd

<https://github.com>



Vectra Cognito Detect

<https://www.vectra.ai>



IBM Security QRadar XDR

<https://www.ibm.com>



Cynet 360

<https://www.cynet.com>

Module Summary



- ❑ In this module, we have discussed the following:
 - How attackers discover live hosts from a range of IP addresses by sending various ping scan requests to multiple hosts
 - How attackers perform different scanning techniques to determine open ports, services, service versions, etc. on the target system
 - How attackers perform banner grabbing or OS fingerprinting to determine the operating system running on a remote target system
 - Various scanning techniques that attackers can employ to bypass IDS/firewall rules and logging mechanisms, and disguise themselves as regular network traffic
 - Network scanning countermeasures to defend against network scanning attacks
- ❑ In the next module, we will discuss in detail how attackers, as well as ethical hackers and pen-testers, perform enumeration to collect information about a target before an attack or audit